

UNIVERSIDAD AUTÓNOMA DE SINALOA
COLEGIO DE INGENIERÍA Y TECNOLOGÍA
FACULTAD DE INGENIERÍA MOCHIS
PROGRAMA DE LICENCIATURA EN INGENIERÍA DE SOFTWARE



“Sistema Gestor de Citas e Historial Médico”

TESIS

**QUE COMO REQUISITO PARA OBTENER EL GRADO DE
LICENCIADO EN INGENIERÍA DE SOFTWARE**

PRESENTA:

Lugo Franco Julio Cesar

Marquez Verdugo Cristhian Manuel

DIRECTOR DE LA TESIS

M.C. Mirsa Paolo Inzunza Martínez

CO-DIRECTOR

Dr. Herman Geovany Ayala Zuñiga

Agradecimientos

.

Resumen

.

Objetivos

Objetivo General

Diseñar e implementar un sistema web centrado en el paciente para la gestión y control de acceso al historial médico electrónico, incorporando mecanismos de autenticación, autorización y trazabilidad alineados con principios de confidencialidad, integridad y disponibilidad de la información (ISO/IEC, 2022a; NIST, 2020).

Objetivo Específicos

- Analizar la problemática de fragmentación del historial médico y su impacto en la continuidad del tratamiento mediante revisión documental y contextualización del sector salud.
- Identificar y definir los requerimientos funcionales y no funcionales del sistema considerando estándares de interoperabilidad como HL7 y FHIR, así como principios de seguridad de la información (HL7 International, 2019; Benson & Grieve, 2016).
- Diseñar e implementar la arquitectura del sistema web, incluyendo el modelo de base de datos y el esquema de control de acceso centrado en el paciente mediante generación y validación de tokens temporales.
- Validar el funcionamiento del sistema mediante pruebas técnicas y evaluación con usuarios potenciales, utilizando métricas de desempeño, disponibilidad de información y percepción de seguridad.

Índice General

Agradecimientos	iii
Resumen	iii
Objetivos	iv
Índice General	v
Índice de Tablas	vii
Índice de Figuras	viii

1 9

1.1. 9

1.2. 10

1.3. 12

1.4. 18

1.5. 19

2 ¡Error! Marcador no definido.

3 30

3.1 Análisis 11

3.2 Diseño 11

3.2.1 Arquitectura 11

3.2.2 Casos de uso 11

3.2.3 Diagramas de secuencia 11

3.2.4 Diagrama entidad-relación 11

3.2.5 Algoritmos 11

3.2.6 Interfaces 11

3.3 Implementación 11

4 65

5 65

Anexos 14

Anexo 1 14

Anexo 2 14

Índice de Tablas

Tabla1 - Ejemplos de axiomas

47

Índice de Figuras

No table of figures entries found.

1 Introducción

1.1. Antecedentes

En las últimas décadas, el sector salud ha experimentado una transformación significativa impulsada por la digitalización de procesos clínicos y administrativos. La adopción de Expedientes Clínicos Electrónicos (ECE) ha permitido sustituir progresivamente los registros en papel, facilitando el almacenamiento estructurado de datos médicos y reduciendo errores asociados a documentación manual (Bates et al., 1998; Menachemi & Collum, 2011; Kruse et al., 2018).

Sin embargo, la mayoría de los sistemas implementados operan de manera institucional y cerrada. Cada hospital, clínica o consultorio mantiene su propio sistema de información sin interoperabilidad efectiva con otras entidades. Esto genera ecosistemas aislados donde la información médica del paciente permanece fragmentada (Vest & Gamm, 2010; Adler-Milstein & Jha, 2017; HL7 International, 2019).

Diversos estudios en salud digital han señalado que la fragmentación de datos clínicos constituye uno de los principales obstáculos para garantizar continuidad asistencial, especialmente en pacientes con enfermedades crónicas, tratamientos prolongados o atención multidisciplinaria (Kripalani et al., 2007; Sittig & Singh, 2012).

En el contexto mexicano, aunque existen iniciativas de digitalización en instituciones públicas y privadas, no existe un modelo ampliamente adoptado que permita al paciente ejercer control explícito sobre quién accede a su información médica, bajo un esquema formal de autorización, trazabilidad y auditoría (Secretaría de Salud, 2012a; Diario Oficial de la Federación, 2010).

Adicionalmente, las soluciones comerciales actuales suelen estar orientadas a la gestión hospitalaria interna (agenda, facturación, inventarios), más que a un modelo centrado en el paciente como propietario de su información clínica.

Este panorama evidencia la necesidad de una propuesta tecnológica que:

- Centralice la información médica.
- Permita la interoperabilidad controlada.
- Implemente mecanismos robustos de seguridad.
- Coloque al paciente como eje del modelo de autorización.

1.2. Planteamiento del Problema

En el sistema de salud actual, la información médica de los pacientes se encuentra distribuida entre múltiples instituciones, especialistas y plataformas tecnológicas. Cada consulta genera datos clínicos —diagnósticos, estudios, recetas, antecedentes y resultados de laboratorio— que permanecen almacenados en sistemas independientes, sin mecanismos efectivos de interoperabilidad.

En las últimas décadas, el sector salud ha experimentado una transformación significativa impulsada por la digitalización de procesos clínicos y administrativos. La adopción de Expedientes Clínicos Electrónicos (ECE) ha permitido sustituir progresivamente los registros en papel, facilitando el almacenamiento estructurado de datos médicos y reduciendo errores asociados a documentación manual (Bates et al., 1998; Menachemi & Collum, 2011; Kruse et al., 2018).

Expediente fragmentado

La fragmentación del expediente clínico constituye una problemática estructural en la atención médica contemporánea. Cuando un paciente consulta distintos especialistas, cada profesional conserva la información generada dentro de su propio sistema o archivo institucional. Esta dispersión provoca que el historial médico se encuentre incompleto al momento de la consulta.

Las principales consecuencias de esta fragmentación son:

- Falta de acceso al historial clínico completo (Cimino, 2013; Giardina et al., 2014).
- Duplicidad de estudios diagnósticos.
- Riesgo de prescripciones incompatibles.

- Retrasos en la toma de decisiones médicas.
- Incremento de costos para pacientes e instituciones.

Desde la perspectiva de la ingeniería de software aplicada a la salud, esta problemática evidencia la limitada adopción de estándares de interoperabilidad como HL7 y FHIR, los cuales buscan facilitar el intercambio estructurado de información clínica entre diferentes sistemas de información (HL7 International, 2019).

Falta de disponibilidad y control por parte del paciente

En la mayoría de los casos, el paciente no dispone de acceso consolidado a su historial médico ni cuenta con mecanismos formales para autorizar de manera inmediata el acceso a su información clínica. Asimismo, desconoce quién ha consultado sus datos y bajo qué circunstancias.

Este modelo pasivo limita la autonomía del paciente y genera vulnerabilidades tanto operativas como legales, especialmente considerando que la información médica es un dato sensible protegido por la Ley Federal de Protección de Datos Personales en Posesión de los Particulares y por marcos internacionales como HIPAA y el General Data Protection Regulation (Diario Oficial de la Federación, 2010; Secretaría de Salud, 2012b).

La ausencia de mecanismos de autorización explícita, trazabilidad y revocación de acceso compromete la seguridad y continuidad de la atención médica.

Problema Central

El problema radica en la inexistencia de un sistema web interoperable y seguro, centrado en el paciente, que permita centralizar el historial médico electrónico, gestionar autorizaciones explícitas de acceso y garantizar trazabilidad en la consulta de información clínica, afectando la continuidad, calidad y seguridad de la atención médica.

1.3. Preguntas de Investigación

¿Cómo influye la fragmentación del historial médico en la continuidad y calidad de la atención en pacientes que consultan múltiples profesionales de la salud?

¿Qué requerimientos funcionales y no funcionales son necesarios para diseñar un sistema web centrado en el paciente que gestione el acceso al historial médico electrónico?

¿Qué mecanismos de autenticación y autorización permiten garantizar la confidencialidad y trazabilidad en el acceso a datos médicos sensibles? (Diario Oficial de la Federación, 2010; ISO/IEC, 2022a)

¿En qué medida la implementación del sistema mejora la disponibilidad de la información clínica y la percepción de seguridad por parte de los usuarios?

1.4. Justificación

La fragmentación del historial médico representa un desafío estructural que impacta directamente en la calidad, continuidad y seguridad de la atención sanitaria. En muchos entornos clínicos, la información del paciente se encuentra distribuida en múltiples sistemas, hospitales o consultorios, lo que dificulta su consulta integral por parte de los profesionales de la salud. Esta situación provoca que los médicos no siempre disponen de información completa y actualizada sobre antecedentes clínicos, tratamientos previos, estudios de laboratorio o diagnósticos anteriores.

En este contexto, surge la necesidad de desarrollar soluciones tecnológicas que permitan gestionar el historial médico desde un enfoque centrado en el paciente, donde el usuario tenga mayor control sobre su información de salud y pueda decidir quién accede a ella. Este enfoque ha sido promovido como una estrategia para mejorar la calidad del servicio y la seguridad de la información médica (World Health Organization, 2021; Tang et al., 2006; Poss-Doering et al., 2018; Baudendistel et al., 2015).

La ausencia de interoperabilidad entre sistemas clínicos provoca diversos problemas operativos dentro del proceso de atención médica. Entre estos se encuentran la duplicidad de estudios diagnósticos, retrasos en la toma de decisiones clínicas, aumento de costos para los pacientes y una mayor carga administrativa para las instituciones de salud. Además, la falta de acceso inmediato a información relevante puede afectar la continuidad del tratamiento y, en casos críticos, comprometer la seguridad del paciente.

Desde una perspectiva tecnológica, muchas de las soluciones existentes en el ámbito de los sistemas de información en salud están diseñadas principalmente para la gestión interna de hospitales o clínicas. Estos sistemas suelen priorizar procesos administrativos, facturación o control institucional, dejando en segundo plano el papel del paciente como propietario y gestor activo de su propia información médica. Como consecuencia, el paciente tiene un control limitado sobre quién puede acceder a sus datos clínicos y en qué circunstancias (Boonstra & Broekhuis, 2010; Goldzweig et al., 2009).

En este contexto, surge la necesidad de desarrollar soluciones tecnológicas que permitan gestionar el historial médico electrónico desde un enfoque centrado en el paciente. Este enfoque promueve un modelo en el cual el individuo tiene mayor control sobre su información personal de salud, pudiendo autorizar o restringir el acceso a profesionales médicos de manera segura y transparente.

El presente proyecto propone una solución tecnológica innovadora basada en un modelo de control de acceso explícito, en el cual el paciente tiene la capacidad de generar autorizaciones temporales mediante tokens únicos. Estos tokens permiten que los profesionales de la salud accedan al historial médico únicamente durante el periodo autorizado y bajo un nivel de permisos previamente definido. Además, el sistema incorpora un mecanismo de registro de auditoría que permite mantener trazabilidad completa de todos los accesos realizados, así como la posibilidad de revocar permisos en cualquier momento (Hardt, 2012; Jones et al., 2015; Ferraiolo et al., 2001).

Este enfoque busca mejorar la seguridad y transparencia en el manejo de la información médica, alineándose con principios fundamentales de seguridad de la información como la confidencialidad, integridad y disponibilidad de los datos. Asimismo, el diseño del sistema considera conceptos relacionados con estándares internacionales de interoperabilidad en salud, como HL7 FHIR, con el objetivo de facilitar futuras integraciones con otras plataformas o sistemas clínicos.

Por otra parte, la propuesta se sustenta en la importancia del cumplimiento de marcos normativos relacionados con la protección de datos personales y la privacidad de la información médica. El tratamiento de datos de salud requiere mecanismos robustos de control de acceso, registro de actividad y consentimiento informado, elementos que son considerados dentro del diseño del sistema (NIST, 2020; OWASP Foundation, 2021; Saltzer & Schroeder, 1975).

En términos generales, se espera que el desarrollo de este sistema contribuya a mejorar la gestión y disponibilidad de la información clínica, proporcionando una herramienta que permita un acceso controlado, seguro y eficiente a los datos médicos del paciente. De esta manera, el sistema puede aportar beneficios tanto para los pacientes como para los profesionales de la salud, al facilitar la consulta de información relevante en el momento oportuno.

A partir de esta propuesta se espera:

- Mejorar la disponibilidad oportuna de la información clínica para los profesionales de la salud.
- Reducir la duplicidad de estudios diagnósticos derivados de la falta de acceso a antecedentes médicos.
- Incrementar la percepción de seguridad y confianza de los pacientes en el manejo de sus datos médicos.
- Fortalecer la continuidad asistencial al facilitar el intercambio controlado de información clínica entre distintos profesionales de la salud.
- Promover un modelo de gestión de información médica centrado en el paciente y basado en principios de seguridad y control de acceso.

1.5. Viabilidad

La viabilidad del presente proyecto se analizó considerando distintos aspectos fundamentales que permiten determinar si la propuesta puede desarrollarse e implementarse de manera realista dentro del contexto académico en el que se plantea. Para ello se evaluaron factores técnicos, operativos, económicos y tecnológicos, con el objetivo de asegurar que el sistema propuesto puede construirse utilizando los recursos disponibles y dentro del alcance establecido para el prototipo.

Viabilidad técnica

Desde el punto de vista técnico, el proyecto es viable debido a la disponibilidad de herramientas, tecnologías y marcos de desarrollo que permiten implementar la solución propuesta. El sistema se plantea como una aplicación web compuesta por una arquitectura en capas, utilizando tecnologías modernas ampliamente utilizadas en el desarrollo de software (Sommerville, 2016; Pressman & Maxim, 2020) (Bass et al., 2021; Fowler, 2002) (Fielding, 2000; Mozilla Developer Network, 2024).

Para la capa de presentación se contempla el uso de un framework de desarrollo frontend que permite construir interfaces dinámicas y responsivas para los diferentes tipos de usuario del sistema, tales como pacientes, médicos y administradores. En la capa de lógica de negocio se emplea un framework backend que permite gestionar la autenticación de usuarios, el procesamiento de solicitudes, la generación y validación de tokens de acceso y la aplicación de reglas de autorización.

Asimismo, el sistema contempla el uso de un gestor de base de datos para el almacenamiento de la información relacionada con los usuarios, historiales médicos, tokens de acceso y registros de auditoría. Estas tecnologías cuentan con documentación amplia, comunidades activas y soporte suficiente para facilitar su implementación dentro del desarrollo del prototipo (Silberschatz et al., 2020; Elmasri & Navathe, 2016).

Además, las herramientas de desarrollo, control de versiones y gestión de código permiten organizar de manera adecuada el proceso de construcción del sistema, facilitando el mantenimiento y la evolución del proyecto.

Viabilidad operativa

La viabilidad operativa se refiere a la capacidad del sistema para ser utilizado de manera efectiva por los actores involucrados. En este caso, el sistema está diseñado para ser utilizado por tres tipos principales de usuarios: pacientes, médicos y administradores.

El diseño de la interfaz busca priorizar la simplicidad y claridad en la interacción, permitiendo que cada tipo de usuario acceda únicamente a las funciones que le corresponden según su rol dentro del sistema. Por ejemplo, el paciente tiene la capacidad de registrar y gestionar su historial médico, así como generar tokens de acceso para autorizar la consulta de su información clínica. El médico puede consultar la información únicamente cuando cuenta con una autorización válida, mientras que el administrador se encarga de validar registros y gestionar la plataforma.

Debido a que el sistema se implementa como una aplicación web, los usuarios pueden acceder a él mediante un navegador estándar sin necesidad de instalar software adicional. Esto facilita su adopción y reduce las barreras de uso, lo que contribuye a su viabilidad operativa dentro del contexto de un prototipo funcional.

Viabilidad económica

En términos económicos, el desarrollo del sistema resulta viable debido a que se basa principalmente en el uso de herramientas de desarrollo y tecnologías de código abierto. Esto permite evitar costos asociados con licencias de software propietarias y facilita la implementación del prototipo utilizando recursos disponibles de forma gratuita o con costos mínimos (Open Source Initiative, 2007; PostgreSQL Global Development Group, 2024).

Asimismo, el desarrollo del proyecto se realiza dentro de un entorno académico, lo que implica que los recursos humanos necesarios para su implementación corresponden principalmente al trabajo del desarrollador del proyecto. Esto reduce significativamente los costos asociados al desarrollo.

La infraestructura necesaria para ejecutar el sistema también puede implementarse utilizando recursos básicos de hardware o servicios de alojamiento accesibles, lo que demuestra que la propuesta puede desarrollarse sin requerir inversiones significativas.

Viabilidad tecnológica

Desde la perspectiva tecnológica, el proyecto es viable debido a que las tecnologías utilizadas para su desarrollo son actuales, ampliamente adoptadas y compatibles con arquitecturas modernas de aplicaciones web.

El uso de una arquitectura modular basada en capas permite separar claramente la interfaz de usuario, la lógica de negocio y el almacenamiento de datos. Esto facilita la escalabilidad del sistema y permite que futuras versiones del proyecto puedan integrar nuevas funcionalidades o mejoras de seguridad sin afectar significativamente su estructura base (Bass et al., 2021; Gamma et al., 1994).

Además, el diseño del sistema considera conceptos relacionados con la interoperabilidad de sistemas de salud, particularmente mediante la referencia conceptual a estándares como HL7 FHIR. Aunque la implementación completa de dichos estándares no forma parte del alcance del prototipo, su consideración en el diseño permite que el sistema pueda adaptarse en el futuro para integrarse con plataformas de información médica existentes.

Conclusión de viabilidad

A partir del análisis de los aspectos técnicos, operativos, económicos y tecnológicos, se concluye que el proyecto es viable para su desarrollo dentro del contexto académico en el que se plantea. La disponibilidad de herramientas adecuadas, la

utilización de tecnologías accesibles y la definición de un alcance claro permiten construir un prototipo funcional que demuestre la viabilidad del modelo propuesto para la gestión y control de acceso al historial médico electrónico.

Este análisis de viabilidad respalda la implementación del sistema y establece una base sólida para el desarrollo de las etapas posteriores del proyecto, incluyendo el diseño detallado, la implementación del prototipo y su evaluación.

1.6. Metodología

El desarrollo del presente proyecto se llevó a cabo mediante una metodología de trabajo orientada al desarrollo iterativo de software, combinando elementos del ciclo de vida de desarrollo de sistemas (SDLC) con prácticas ágiles basadas en la metodología Scrum. Este enfoque permitió estructurar el proceso de investigación, análisis, diseño e implementación del sistema de manera organizada y progresiva (Schwaber & Sutherland, 2020; Sommerville, 2016) (Pressman & Maxim, 2020; IEEE Computer Society, 2014).

En una primera etapa se realizó un análisis del problema, en el cual se identificó la situación actual relacionada con la fragmentación del historial médico electrónico y las limitaciones existentes en cuanto al control de acceso a la información clínica. Durante esta fase se revisaron antecedentes conceptuales sobre sistemas de información en salud, seguridad de datos médicos e interoperabilidad, con el objetivo de comprender el contexto en el que se desarrolla la problemática.

Posteriormente se llevó a cabo la identificación de requerimientos del sistema, tanto funcionales como no funcionales. En esta etapa se definieron las principales funcionalidades que debía incluir el sistema, tales como el registro de usuarios, la gestión del historial médico electrónico, la generación de tokens de acceso y el registro de auditoría. Asimismo, se establecieron requisitos relacionados con seguridad, confidencialidad, disponibilidad y usabilidad.

En la fase de diseño del sistema se elaboraron modelos conceptuales utilizando diagramas UML, los cuales permitieron representar gráficamente la estructura del

sistema y la interacción entre sus componentes. Entre los diagramas desarrollados se incluyen diagramas de casos de uso, diagramas de flujo y modelos de arquitectura del sistema. Esta etapa también contempló la definición de la arquitectura tecnológica basada en una estructura de tres capas: presentación, lógica de negocio y datos (Object Management Group, 2017).

Una vez definido el diseño, se procedió a la fase de implementación del prototipo, en la cual se desarrolló una aplicación web que permite simular el funcionamiento del sistema propuesto. Durante esta fase se utilizaron tecnologías modernas de desarrollo web tanto para el frontend como para el backend, permitiendo construir una plataforma funcional que represente el modelo de gestión de acceso al historial médico.

Finalmente, se realizó una fase de pruebas y validación del prototipo, con el objetivo de verificar que las funcionalidades implementadas cumplieran con los requerimientos definidos en las etapas anteriores. Estas pruebas permitieron comprobar el correcto funcionamiento de los mecanismos de autenticación, generación de tokens de acceso, control de permisos y registro de auditoría.

En conjunto, la metodología aplicada permitió desarrollar un prototipo funcional que demuestra la viabilidad del modelo propuesto para la gestión segura del historial médico electrónico, proporcionando una base conceptual y técnica para futuros desarrollos o investigaciones en el área de sistemas de información en salud.

1.7. Organización del documento

2 Marco Teórico

2.1 Temas relacionados

El marco teórico del proyecto se organiza a partir de cinco conceptos principales: expediente clínico electrónico, historial o registro personal de salud, interoperabilidad, seguridad de la información y arquitectura de sistemas web. Estos conceptos permiten fundamentar por qué el sistema propuesto no se limita a almacenar datos médicos, sino que busca resolver un problema de acceso, control y trazabilidad. En el contexto de la salud digital, la utilidad de una plataforma no depende únicamente de que exista una base de datos, sino de que la información pueda consultarse de manera oportuna, protegerse frente a accesos no autorizados y mantenerse vinculada al paciente durante su recorrido por distintos servicios de atención (Menachemi & Collum, 2011; Kruse et al., 2018).

2.1.1 Expediente clínico electrónico y fragmentación de información

El expediente clínico electrónico se entiende como una representación digital de la información médica generada durante la atención de un paciente. Puede contener datos de identificación, antecedentes, diagnósticos, tratamientos, observaciones clínicas, resultados de estudios y registros de consulta. A diferencia del expediente físico, el formato electrónico facilita la consulta, actualización y almacenamiento estructurado de la información; sin embargo, su adopción no garantiza por sí misma continuidad asistencial. Cuando cada institución o profesional utiliza sistemas independientes, los datos pueden quedar aislados y perder valor clínico al no estar disponibles en el momento de la atención (Bates et al., 1998; Cimino, 2013).

La fragmentación del expediente médico es especialmente relevante en pacientes que reciben atención de varios especialistas o que cambian de institución. En estos casos, el médico puede no conocer tratamientos previos, alergias, diagnósticos anteriores o estudios recientes, lo cual puede derivar en duplicidad de pruebas, retrasos o decisiones basadas en información incompleta. Desde la ingeniería de software, este problema puede analizarse como una falla de disponibilidad, integración y gobierno de datos: la información existe, pero no se encuentra

organizada en un punto accesible, ni cuenta con reglas claras para su consulta segura (Kripalani et al., 2007; Vest & Gamm, 2010).

El sistema propuesto aborda esta problemática mediante una plataforma centralizada para fines académicos, en la que el historial médico del paciente se almacena en una base de datos relacional y se consulta mediante módulos web. Aunque el prototipo no se integra directamente con hospitales reales, su diseño permite representar el flujo básico de un expediente consultable por el paciente y compartible con profesionales de la salud bajo autorización explícita. Esta decisión delimita el alcance del proyecto y al mismo tiempo permite validar los componentes esenciales del modelo: registro, consulta, autorización temporal y trazabilidad.

2.1.2 Registros personales de salud y enfoque centrado en el paciente

Los registros personales de salud, conocidos como Personal Health Records, proponen que el paciente tenga un papel más activo en la gestión de su información médica. Este enfoque no significa que el paciente sustituya al profesional de la salud, sino que cuente con herramientas para consultar, organizar y compartir información relevante cuando sea necesario. Diversos estudios han señalado que el acceso del paciente a su expediente puede fortalecer la percepción de control, mejorar la comunicación con los profesionales y favorecer una participación más informada en el proceso de atención (Tang et al., 2006; Giardina et al., 2014).

En esta tesis, el enfoque centrado en el paciente se materializa en dos decisiones de diseño. La primera es que el paciente conserva acceso directo a su perfil, historial médico, tokens generados y auditoría de accesos. La segunda es que el acceso del médico no se asume como permanente, sino como una autorización que debe ser emitida por el propio paciente. Esta lógica se diferencia de modelos institucionales tradicionales, donde el control suele recaer en la organización que resguarda el expediente. El objetivo es que el paciente tenga una participación clara en la decisión de quién consulta su información, por cuánto tiempo y con qué nivel de permiso.

El modelo no elimina la responsabilidad clínica del médico ni convierte al paciente en administrador técnico del sistema. Más bien, proporciona una interfaz

simplificada para ejercer control sobre acciones concretas: generar un token, definir vigencia, seleccionar nivel de acceso, compartir el código con un profesional y revisar posteriormente los eventos asociados. De esta manera, el diseño busca equilibrar autonomía, facilidad de uso y seguridad, evitando que el control del paciente dependa de procesos administrativos complejos.

2.1.3 Interoperabilidad y estándares de información en salud

La interoperabilidad se refiere a la capacidad de diferentes sistemas para intercambiar, interpretar y utilizar información de manera coherente. En salud, este concepto es fundamental porque los datos clínicos pueden generarse en laboratorios, consultorios, hospitales, farmacias o plataformas de seguimiento. Estándares como HL7 y FHIR buscan facilitar la representación estructurada de recursos clínicos y la comunicación entre sistemas heterogéneos (Benson & Grieve, 2016; HL7 International, 2019).

El prototipo desarrollado no implementa de forma completa HL7 FHIR, pero toma el estándar como referencia conceptual para organizar la información alrededor de entidades clínicas identificables, tales como paciente, médico, registro médico y eventos de acceso. Esta decisión es importante porque permite que el sistema no sea concebido como una aplicación aislada sin proyección futura, sino como una base que podría evolucionar hacia esquemas de intercambio más formales. En una versión posterior, los registros médicos podrían mapearse a recursos FHIR y exponerse mediante servicios compatibles con integraciones externas.

2.1.4 Seguridad, control de acceso y trazabilidad

La información médica pertenece a una categoría especialmente sensible, ya que puede revelar condiciones de salud, tratamientos, diagnósticos, antecedentes personales y otros datos que afectan directamente la privacidad del individuo. Por ello, el diseño de un sistema de historial médico debe considerar principios de confidencialidad, integridad y disponibilidad. La confidencialidad implica restringir el acceso a usuarios autorizados; la integridad exige preservar la exactitud de los datos; y la disponibilidad busca que la información pueda consultarse cuando se requiere para apoyar la atención (ISO/IEC, 2022a; NIST, 2020).

El control de acceso implementado en el prototipo combina autenticación, autorización basada en roles y tokens temporales. La autenticación permite identificar al usuario mediante credenciales y sesión segura; la autorización basada en roles diferencia las acciones disponibles para pacientes, médicos y administradores; y el token temporal funciona como un mecanismo de permiso explícito emitido por el paciente. Este diseño se relaciona con modelos de control de acceso que buscan asignar privilegios de acuerdo con funciones y condiciones específicas del sistema (Ferraiolo et al., 2001; Hardt, 2012; Jones et al., 2015).

La trazabilidad complementa el control de acceso porque no basta con permitir o negar operaciones: también es necesario dejar evidencia de los eventos relevantes. En el sistema, la auditoría registra acciones como consulta de perfil, actualización de datos, creación de registros médicos o accesos al historial. Estos registros permiten responder preguntas como quién realizó una acción, cuándo ocurrió y sobre qué paciente se ejecutó. Para un sistema de salud, esta información es valiosa porque fortalece la transparencia y permite detectar usos indebidos o comportamientos anómalos (NIST, 2020; ISO/IEC, 2022b).

2.1.5 Arquitectura web del sistema

La arquitectura del sistema se organiza en tres capas: presentación, lógica de negocio y datos. La capa de presentación corresponde a la aplicación web desarrollada con Angular, donde el usuario interactúa con formularios, tablas, paneles y vistas específicas de su rol. La capa de lógica de negocio se implementa mediante NestJS, encargado de procesar solicitudes, aplicar reglas de autorización, validar tokens y coordinar operaciones con los servicios internos. Finalmente, la capa de datos almacena entidades como usuarios, pacientes, médicos, historiales, tokens y registros de auditoría mediante un modelo relacional (Fowler, 2002; Bass et al., 2021).

Esta separación por capas facilita el mantenimiento del prototipo porque cada parte del sistema cumple una responsabilidad definida. La interfaz no accede directamente a la base de datos, sino que se comunica con servicios del backend mediante endpoints HTTP. A su vez, el backend encapsula reglas de negocio en

controladores y servicios, lo cual permite modificar la lógica del sistema sin alterar necesariamente la estructura visual. Esta organización también favorece futuras ampliaciones, como agregar nuevos roles, nuevos tipos de registros clínicos o mecanismos adicionales de seguridad.

2.1.6 Usabilidad e interacción con el usuario

La usabilidad es un aspecto crítico en sistemas de salud porque los usuarios pueden tener distintos niveles de experiencia tecnológica. Un sistema seguro pero difícil de utilizar puede provocar errores, abandono o uso incorrecto de la información. Por ello, las interfaces del prototipo se diseñan con formularios claros, mensajes de validación, paneles con indicadores, tablas de consulta y estados vacíos que orientan al usuario cuando todavía no existen registros. Estos elementos buscan reducir ambigüedad y mejorar la comprensión del flujo de interacción (Nielsen, 1994; Norman, 2013).

En el caso del paciente, la interfaz prioriza acciones como consultar su historial, generar tokens, revisar accesos y actualizar datos personales. En el caso del médico, el diseño debe facilitar la validación de un token, consulta del historial autorizado y registro de una consulta médica cuando el permiso lo permite. En el caso del administrador, la interfaz se orienta a la supervisión de usuarios y validación de médicos. Esta diferenciación por rol ayuda a que cada usuario visualice únicamente las funciones necesarias para su operación dentro del sistema.

2.2 Trabajos relacionados

2.2.1 Poss-Doering et al. (2018)

Poss-Doering y colaboradores reportan un estudio posprueba sobre un **prototipo de expediente clínico electrónico controlado por el paciente en Alemania**. El artículo se centra en las experiencias, percepciones y perspectivas de los usuarios sobre ese prototipo. Su relevancia para tu tesis es muy alta porque se trata de una implementación explícitamente “patient-controlled”, es decir, orientada a que el paciente tenga mayor control sobre su información. No obstante, por la descripción

disponible, el foco del trabajo está más en la percepción y experiencia de uso que en una arquitectura práctica basada en roles, auditoría y tokens temporales como la que tú propones.

2.2.2 Giardina et al. (2013)

Giardina y colegas realizaron una revisión sistemática sobre el acceso de los pacientes a sus expedientes médicos, evaluando su impacto en calidad, efectividad, centralidad en el paciente y eficiencia. Revisaron 27 estudios y encontraron resultados mixtos, aunque en general el acceso del paciente parecía mejorar la percepción de control y no incrementar de manera consistente la ansiedad. Este estudio no desarrolla un sistema específico, pero sí es importante porque demuestra que dar acceso al paciente a su expediente es una línea consolidada de investigación y que tiene efectos positivos en percepción de control, comunicación y participación.

2.2.3 Hosseini et al. (2021)

Hosseini y colaboradores desarrollaron una revisión sistemática sobre las funciones y resultados de los **Personal Health Records (PHR)** para pacientes con enfermedades crónicas. Encontraron 35 estudios relevantes y concluyeron que los PHR permiten a los pacientes acceder, gestionar, rastrear y compartir su información de salud. El trabajo recomienda sistemas integrados con funciones ampliadas para promover independencia, empoderamiento y mejor autocuidado. Esta investigación es muy útil para tu tesis porque respalda el valor del enfoque centrado en el paciente y del manejo activo de información médica por parte del usuario, aunque no se centra específicamente en autorización temporal por token ni en control de acceso granular con auditoría.

2.2.4 Cichosz et al. (2019)

Cichosz y colaboradores presentan un concepto operativo para usar blockchain en la gestión y compartición de datos de salud en diabetes. La propuesta ubica al

paciente como centro del gobierno de sus datos y utiliza criptografía, contratos multifirma y mecanismos de acceso para compartir información con privacidad. El artículo es relevante porque comparte contigo dos ideas clave: el control del acceso por parte del paciente y la necesidad de trazabilidad segura. Sin embargo, su enfoque está orientado a una arquitectura blockchain más compleja, lo que puede dificultar su adopción en contextos académicos o institucionales donde se requiere un prototipo más implementable en el corto plazo.

2.2.5 Zhan et al. (2022)

Zhan y colaboradores proponen un sistema de compartición de EMR basado en **Hyperledger Fabric** e **IPFS**, con control de acceso por atributos, proxy re-encryption y un módulo de tokens. El trabajo busca resolver problemas clásicos como duplicidad de estudios, pérdida de registros, falta de trazabilidad y debilidades de privacidad al compartir expedientes entre instituciones. Es una de las investigaciones más cercanas a tu tema por su énfasis en acceso seguro, trazabilidad y uso de tokens; sin embargo, su orientación principal está en blockchain consorcial, intercambio interinstitucional e incentivos, más que en un sistema web práctico, centrado en roles clínicos y pensado para implementación académica con Angular, NestJS y MySQL.

2.2.6 Lugo Franco y Márquez Verdugo (2026)

Lugo Franco Julio César y Márquez Verdugo Cristhian Manuel (2026) proponen el desarrollo de un sistema web orientado a la gestión y control de acceso al historial médico electrónico centrado en el paciente. La propuesta surge como respuesta a la fragmentación de la información clínica y a la falta de control por parte del paciente sobre quién accede a sus datos médicos.

El sistema se basa en una arquitectura web en tres capas (presentación, lógica de negocio y datos), implementada mediante tecnologías modernas como Angular para el frontend y NestJS para el backend, con almacenamiento en una base de datos MySQL. La solución incorpora un modelo de control de acceso basado en roles

(Paciente, Médico y Administrador), así como un mecanismo de autorización mediante tokens generados por el propio paciente.

Una de las características principales del sistema es que el paciente puede generar tokens temporales con distintos niveles de acceso (lectura o edición), los cuales permiten a los médicos consultar o modificar el historial clínico únicamente durante el periodo autorizado. Además, el sistema incluye un módulo de auditoría que registra todos los accesos realizados, garantizando trazabilidad y transparencia en el uso de la información médica (NIST, 2020; ISO/IEC, 2022b).

A diferencia de otras propuestas encontradas en la literatura, este sistema no se enfoca únicamente en la teoría o en arquitecturas complejas como blockchain, sino en la implementación de un prototipo funcional que integra control de acceso, trazabilidad y facilidad de uso dentro de un entorno web moderno. Esto permite validar la viabilidad de un modelo centrado en el paciente con un enfoque práctico y aplicable en contextos reales.

Investigación	Tipo de trabajo	Aporte principal	Similitud con la tesis	Limitación frente a la propuesta
Poss-Doering et al. (2018)	Prototipo / análisis cualitativo	EHR controlado por el paciente	Muy alta en enfoque patient-centered	Enfoque en percepción, no en arquitectura funcional completa
Giardina et al. (2013)	Revisión sistemática	Impacto del acceso del paciente a su expediente	Alta en acceso del paciente	No propone sistema funcional
Hosseini et al. (2021)	Revisión sistemática	Funcionalidades de los PHR	Alta en gestión de información por el paciente	No incluye control por tokens ni auditoría
Cichosz et al. (2019)	Propuesta tecnológica	Uso de blockchain para control de datos médicos	Alta en seguridad y control	Complejidad técnica elevada
Zhan et al. (2022)	Propuesta de sistema	Compartición segura de EMR con blockchain	Muy alta en seguridad y trazabilidad	Enfoque complejo y no orientado a implementación web simple
Lugo Franco & Márquez Verdugo (2026)	Prototipo funcional	Sistema web con control por tokens y auditoría	Total (propuesta base)	Prototipo académico, sin integración real con hospitales

2.3 Tabla comparativa

Al hacer la comparación se observa que las investigaciones revisadas abordan problemáticas similares desde enfoques parciales, concentrándose principalmente en aspectos como el acceso del paciente a su información, la interoperabilidad entre

sistemas o la seguridad mediante tecnologías avanzadas. Algunas propuestas destacan la importancia del control del paciente sobre sus datos clínicos, mientras que otras priorizan mecanismos robustos de protección mediante criptografía o blockchain. Sin embargo, estas soluciones tienden a enfatizar un componente específico y no siempre integran, en un mismo prototipo web, historial médico, autorización temporal, niveles de acceso, roles diferenciados y auditoría operativa.

En contraste, la propuesta desarrollada en este documento presenta un enfoque integral al combinar en una sola solución elementos fundamentales como el control de acceso centrado en el paciente, la generación de tokens temporales para autorización, la definición de niveles de permisos, la trazabilidad mediante auditoría y un modelo de roles claramente estructurado. Además, a diferencia de las soluciones más complejas encontradas en la literatura, el sistema propuesto se basa en una arquitectura web moderna y tecnologías accesibles, lo que facilita su implementación y validación en un entorno académico. De esta manera, la principal diferencia radica en que esta propuesta no solo conceptualiza el problema, sino que lo materializa en un prototipo funcional que equilibra seguridad, usabilidad y viabilidad técnica.

3 Metodología

3.1 Análisis

La etapa de análisis tuvo como propósito identificar, comprender y definir los elementos fundamentales que conforman el sistema propuesto, así como establecer los requerimientos necesarios para el diseño e implementación del prototipo. Esta fase constituye una de las etapas más importantes dentro del proceso de desarrollo de software, ya que permite delimitar el problema, identificar a los actores involucrados y establecer claramente las funcionalidades que el sistema debe proporcionar.

El análisis se enfocó principalmente en la problemática relacionada con la fragmentación del historial médico electrónico, una situación frecuente en los sistemas de salud actuales. En muchos casos, la información clínica de un paciente se encuentra distribuida entre múltiples instituciones médicas, consultorios o profesionales de la salud, lo que dificulta la consulta integral del historial médico y puede generar inconsistencias en la información disponible. Esta fragmentación puede provocar duplicidad de estudios clínicos, retrasos en la toma de decisiones médicas y, en algunos casos, diagnósticos basados en información incompleta.

Adicionalmente, se identificó que en muchos sistemas existentes el paciente no tiene un control directo sobre quién puede acceder a su información clínica, lo que genera preocupaciones relacionadas con la privacidad, la seguridad y la protección de datos personales. En este contexto, surge la necesidad de diseñar una solución tecnológica que permita centralizar el historial médico electrónico y, al mismo tiempo, proporcionar mecanismos que permitan al paciente gestionar de manera explícita los permisos de acceso a su información.

Con base en este análisis, se propuso el desarrollo de un sistema web que permita administrar el historial médico electrónico bajo un enfoque centrado en el paciente, incorporando mecanismos de autenticación, autorización y trazabilidad de accesos. Este enfoque busca mejorar la seguridad de la información médica y ofrecer mayor transparencia en el uso de los datos clínicos.

A partir de este análisis inicial se identificaron los actores principales del sistema, se delimitó el alcance funcional de la solución y se definieron los requerimientos necesarios para el diseño e implementación del prototipo.

3.1.1 Actores del sistema

- Durante la fase de análisis se identificaron los principales actores que interactúan con el sistema. Un actor representa cualquier entidad externa que interactúa con el sistema para realizar una acción o recibir un servicio. En este caso, los actores corresponden a los diferentes tipos de usuarios que participan en la gestión y consulta del historial médico electrónico.

Paciente

El paciente es el actor principal del sistema y representa al propietario del historial médico electrónico. Desde el enfoque propuesto, el paciente tiene un papel central en la gestión de su propia información clínica, lo que implica un cambio respecto a los modelos tradicionales donde el control de los datos suele estar limitado a las instituciones médicas.

Dentro del sistema, el paciente tiene la capacidad de registrar y administrar su información clínica básica, así como visualizar los registros médicos asociados a su historial. Además, puede generar tokens de acceso que permiten compartir temporalmente su información médica con profesionales de la salud cuando sea necesario.

El paciente también puede definir el nivel de permisos que otorga a otros usuarios, especificando si el acceso será únicamente de lectura o si permitirá la edición de determinados datos. Asimismo, puede establecer la vigencia del acceso mediante la definición de un periodo de tiempo específico. En cualquier momento, el paciente tiene la posibilidad de revocar los tokens previamente generados, garantizando así un control completo sobre el acceso a su información.

Este modelo de control contribuye a fortalecer la seguridad y la privacidad de los datos médicos, además de fomentar la participación activa del paciente en la gestión de su historial clínico.

Médico

El médico es el profesional de la salud que puede acceder al historial médico del paciente cuando cuenta con la autorización correspondiente. A diferencia de otros sistemas donde el acceso puede ser permanente o institucional, en el modelo propuesto el médico solo puede consultar la información clínica cuando el paciente le proporciona un token de acceso válido.

El nivel de acceso del médico depende de los permisos definidos por el paciente al momento de generar el token. Esto significa que el médico puede tener únicamente acceso de lectura para consultar información médica existente o, en algunos casos, permisos adicionales para registrar nuevas consultas o actualizar ciertos datos clínicos.

Este mecanismo permite garantizar que el acceso a la información médica se realice de forma controlada, respetando tanto la privacidad del paciente como la necesidad de los profesionales de la salud de consultar información relevante para la atención médica.

Sistema

El sistema actúa como el intermediario encargado de gestionar todas las interacciones entre los actores. Su función principal es validar las credenciales de los usuarios, verificar la autenticidad de los tokens de acceso y aplicar las reglas de autorización definidas dentro de la lógica de negocio.

Además, el sistema es responsable de registrar cada una de las acciones realizadas por los usuarios dentro de un módulo de auditoría. Este registro permite mantener un historial detallado de los accesos realizados al historial médico, incluyendo

información como el usuario que realizó la consulta, la fecha y hora del acceso, así como el tipo de acción ejecutada.

La existencia de este mecanismo de auditoría es fundamental para garantizar la trazabilidad de la información y fortalecer la seguridad del sistema.

3.1.2 Alcance del sistema

El sistema propuesto tiene como alcance principal la gestión y el control del acceso al historial médico electrónico desde un enfoque centrado en el paciente. La solución busca proporcionar una plataforma que permita centralizar la información médica de manera segura, al mismo tiempo que ofrece mecanismos para administrar autorizaciones de acceso temporales y controladas.

Dentro de este alcance, el sistema permite registrar usuarios, administrar perfiles, gestionar historiales médicos electrónicos y controlar el acceso a la información clínica mediante la generación de tokens de autorización. Estos tokens permiten compartir temporalmente el acceso a la información médica con profesionales de la salud, garantizando que únicamente las personas autorizadas puedan consultar o modificar los datos.

Es importante destacar que el sistema no tiene como objetivo sustituir a los sistemas hospitalarios oficiales ni integrarse directamente con bases de datos médicas institucionales. Su función principal es proporcionar una plataforma de gestión y control de acceso que permita mejorar la organización y seguridad de la información clínica del paciente.

Asimismo, el sistema no realiza diagnósticos médicos automatizados ni genera recomendaciones clínicas. Todas las decisiones médicas continúan siendo responsabilidad de los profesionales de la salud. El sistema actúa únicamente como una herramienta de apoyo para la gestión y consulta de la información médica previamente registrada.

3.1.3 Requerimientos funcionales

A partir del análisis del problema y de las necesidades identificadas, se definieron los siguientes requerimientos funcionales del sistema. Estos requerimientos describen las funcionalidades específicas que la plataforma debe proporcionar para cumplir con los objetivos del proyecto.

El sistema debe permitir el registro y autenticación de usuarios, incluyendo tanto pacientes como profesionales de la salud. Cada usuario debe poder crear una cuenta dentro del sistema y posteriormente iniciar sesión utilizando credenciales seguras.

Asimismo, el sistema debe permitir la gestión del perfil de usuario, proporcionando la posibilidad de consultar y actualizar la información personal registrada.

Otra funcionalidad fundamental es la gestión del historial médico electrónico. El sistema debe permitir registrar, consultar y actualizar la información médica asociada a cada paciente, garantizando que dicha información se encuentre organizada y disponible cuando sea necesario.

El sistema también debe permitir que el paciente genere tokens únicos de acceso, los cuales pueden ser utilizados por los médicos para consultar el historial médico. Durante la generación del token, el paciente debe poder definir el nivel de acceso otorgado, especificando si el permiso será únicamente de lectura o si permitirá la edición de la información.

Adicionalmente, el sistema debe validar la autenticidad de los tokens antes de permitir el acceso al historial médico, verificando tanto su validez como su vigencia.

El paciente debe contar con la capacidad de revocar tokens previamente generados en cualquier momento, lo que implica que los accesos autorizados puedan cancelarse de forma inmediata.

Finalmente, el sistema debe registrar en un módulo de auditoría todas las acciones relacionadas con el acceso a la información médica, permitiendo mantener un historial completo de las actividades realizadas dentro de la plataforma.

3.1.4 Requerimientos no funcionales

Además de las funcionalidades descritas anteriormente, el sistema debe cumplir con una serie de requerimientos no funcionales que garantizan la calidad, seguridad y confiabilidad de la solución.

Uno de los aspectos más importantes es la seguridad de la información. Dado que el sistema gestiona datos médicos sensibles, es fundamental implementar mecanismos adecuados de autenticación y autorización que permitan proteger la información contra accesos no autorizados.

La confidencialidad de los datos también constituye un requisito esencial. El acceso a la información médica debe estar limitado exclusivamente a los usuarios que cuenten con autorización explícita del paciente, evitando la exposición indebida de datos personales.

Otro aspecto relevante es la integridad de la información. El sistema debe garantizar que los datos médicos almacenados no puedan ser alterados de forma no autorizada, preservando así la exactitud y confiabilidad de la información clínica.

En términos de disponibilidad, el sistema debe estar accesible a través de una plataforma web que permita a los usuarios consultar la información desde diferentes dispositivos con conexión a internet.

La trazabilidad también es un requisito clave. Cada acceso realizado al historial médico debe quedar registrado dentro del sistema, permitiendo identificar quién accedió a la información, cuándo se realizó el acceso y qué acciones se ejecutaron.

Por otra parte, el sistema debe ofrecer una interfaz clara e intuitiva que facilite su uso por parte de los diferentes tipos de usuarios, considerando que algunos de ellos pueden no tener experiencia avanzada con sistemas informáticos (Nielsen, 1994; Norman, 2013).

Finalmente, el sistema debe alinearse conceptualmente con las normativas relacionadas con la protección de datos personales y la seguridad de la información,

como las leyes de protección de datos aplicables y los estándares internacionales en el ámbito de la salud.

La seguridad en sistemas de información es un aspecto fundamental, especialmente en el ámbito de la salud, donde se manejan datos sensibles. La implementación de controles de seguridad permite proteger la información contra accesos no autorizados y garantizar su integridad (ISO/IEC, 2022a).

3.1.5 Restricciones del sistema

Durante la fase de análisis se identificaron diversas restricciones que delimitan el alcance y las capacidades del sistema propuesto. Estas restricciones permiten establecer con claridad las condiciones bajo las cuales se desarrollará el prototipo, evitando interpretaciones incorrectas sobre las funcionalidades que el sistema pretende cubrir dentro del contexto del proyecto.

Una de las principales restricciones identificadas es que el sistema no se integra directamente con bases de datos hospitalarias reales ni con sistemas clínicos institucionales existentes. Esto se debe principalmente a limitaciones relacionadas con el acceso a infraestructura médica real, así como a consideraciones de seguridad y privacidad de datos clínicos. En consecuencia, el sistema opera de forma independiente utilizando una base de datos propia destinada exclusivamente a fines de demostración y validación del prototipo.

Otra restricción importante es que el sistema no realiza diagnósticos médicos automatizados ni genera recomendaciones clínicas. Las decisiones médicas continúan siendo responsabilidad exclusiva de los profesionales de la salud. El objetivo del sistema es facilitar la gestión y consulta de la información médica del paciente, así como mejorar el control de acceso a dichos datos, pero en ningún momento pretende sustituir el criterio clínico de los especialistas.

Asimismo, la interoperabilidad con estándares internacionales utilizados en sistemas de salud, como el estándar HL7 FHIR, se considera únicamente a nivel

conceptual dentro del diseño del sistema. Esto significa que la arquitectura y la estructura de los datos fueron diseñadas tomando como referencia dichos estándares, con el fin de facilitar posibles integraciones futuras. Sin embargo, la implementación completa de estos estándares queda fuera del alcance del prototipo desarrollado en este proyecto.

Finalmente, es importante señalar que el sistema se desarrolla como un prototipo funcional con fines académicos. Su propósito principal es demostrar la viabilidad de un modelo de gestión de historial médico electrónico centrado en el paciente, así como evaluar la implementación de mecanismos de control de acceso basados en tokens. Debido a este enfoque, algunas funcionalidades avanzadas presentes en sistemas clínicos comerciales no se encuentran implementadas en esta versión del sistema.

A pesar de estas restricciones, el prototipo desarrollado permite validar los conceptos fundamentales del sistema propuesto, así como demostrar la viabilidad técnica de una solución orientada a mejorar el control de acceso a la información médica.

3.1.6 Metodología de diseño

Para el desarrollo del sistema se adoptó un enfoque de desarrollo ágil basado en la metodología Scrum, la cual permite organizar el trabajo en iteraciones cortas y controladas denominadas sprints. Este enfoque resulta especialmente adecuado para proyectos de desarrollo de software, ya que facilita la adaptación a cambios en los requerimientos y permite validar de forma progresiva las funcionalidades implementadas.

Mediante la aplicación de esta metodología, el proyecto fue dividido en varias iteraciones incrementales, cada una de las cuales contempló actividades específicas de análisis, diseño, implementación y pruebas. Durante cada iteración se desarrollaron funcionalidades concretas del sistema, lo que permitió avanzar

gradualmente en la construcción del prototipo y evaluar continuamente el progreso del proyecto.

El uso de una metodología ágil también permitió mantener una organización clara del trabajo, priorizando las funcionalidades más relevantes para el cumplimiento de los objetivos del sistema. De esta manera, las primeras iteraciones se enfocaron en el diseño general del sistema, la definición de los actores y la identificación de los casos de uso principales. Posteriormente, las iteraciones siguientes se centraron en la implementación de los módulos funcionales del sistema, como el registro de usuarios, la gestión del historial médico y el control de acceso mediante tokens.

Durante la fase de diseño del sistema se emplearon diagramas del Lenguaje Unificado de Modelado, conocido como UML, con el objetivo de representar gráficamente la estructura y el comportamiento del sistema. Entre los diagramas utilizados se encuentran los diagramas de casos de uso, los cuales permiten identificar las interacciones entre los actores y el sistema, así como los diagramas que representan los flujos de interacción entre los diferentes componentes.

Además, el proyecto incorporó herramientas de control de versiones mediante la plataforma GitHub, lo que permitió gestionar de manera organizada el código fuente del sistema y mantener un historial de los cambios realizados durante el proceso de desarrollo. El uso de control de versiones facilita el seguimiento de las modificaciones realizadas en el proyecto y permite mantener diferentes versiones del sistema de manera estructurada (Chacon & Straub, 2014; GitHub, 2024).

Finalmente, la documentación técnica del sistema se elaboró siguiendo un enfoque basado en el ciclo de vida de desarrollo de software, conocido como SDLC. Este enfoque permite estructurar el proceso de desarrollo en diferentes fases, incluyendo análisis, diseño, implementación, pruebas y documentación, lo que contribuye a garantizar una mayor organización y claridad en el desarrollo del proyecto.

La aplicación combinada de estas metodologías y herramientas permitió estructurar de manera adecuada el proceso de desarrollo del sistema, asegurando que el

prototipo cumpla con los objetivos planteados y proporcione una base sólida para futuras mejoras o ampliaciones.

3.2 Diseño

3.2.1 Arquitectura

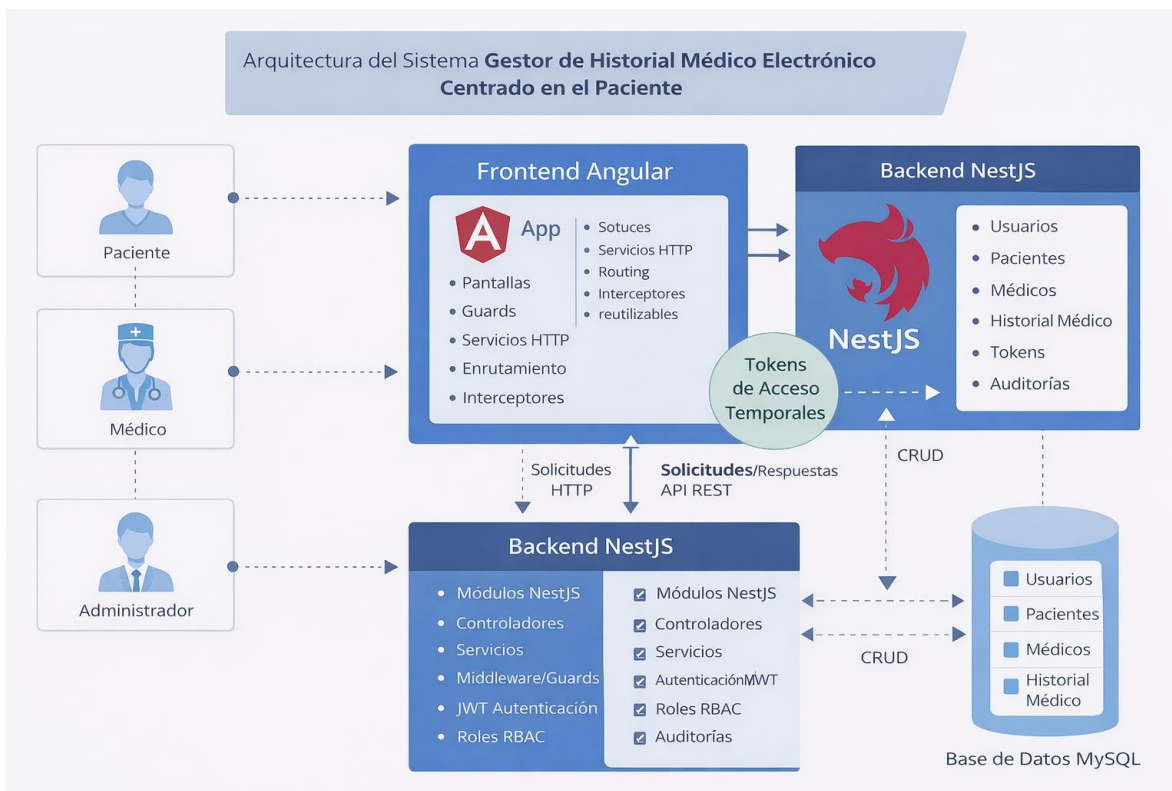


Figura 1. Diagrama de arquitectura general

En la figura 1 se muestra una versión general de la arquitectura que fue diseñada bajo una arquitectura web en tres capas, un modelo ampliamente utilizado en el desarrollo de aplicaciones modernas debido a su capacidad para separar responsabilidades y facilitar el mantenimiento del software.

Esta arquitectura divide el sistema en tres niveles principales: la capa de presentación, la capa de lógica de negocio y la capa de datos. Cada una de estas capas cumple funciones específicas dentro del funcionamiento del sistema.

La capa de presentación es responsable de proporcionar la interfaz de usuario a través de la cual los actores interactúan con el sistema. Esta capa se implementa

mediante una aplicación web accesible desde un navegador, permitiendo a los usuarios realizar operaciones como iniciar sesión, consultar su historial médico, generar tokens de acceso o administrar su información personal. La interfaz está diseñada para adaptarse al rol del usuario, mostrando únicamente las funcionalidades correspondientes a cada tipo de actor.

La capa de lógica de negocio constituye el núcleo del sistema y se encarga de implementar las reglas y procesos que gobiernan el funcionamiento de la plataforma. En esta capa se procesan las solicitudes enviadas desde la interfaz de usuario, se validan las credenciales de los usuarios y se aplican los mecanismos de autorización que determinan qué acciones puede realizar cada actor.

Dentro de esta capa también se gestionan las operaciones relacionadas con la generación y validación de tokens de acceso, así como la aplicación de los niveles de permisos definidos por el paciente. Además, todas las acciones realizadas por los usuarios son registradas dentro de un módulo de auditoría, lo que permite mantener un control detallado de las actividades realizadas en el sistema.

La capa de datos es la encargada de gestionar el almacenamiento persistente de la información. En esta capa se resguardan los datos relacionados con los usuarios del sistema, los historiales médicos electrónicos, los tokens de acceso generados y los registros de auditoría. El acceso a esta capa se encuentra restringido a la lógica de negocio, evitando que la interfaz de usuario interactúe directamente con la base de datos.

Este modelo arquitectónico permite mantener una clara separación entre la interfaz, la lógica del sistema y el almacenamiento de datos, lo que facilita el desarrollo modular, mejora la seguridad y simplifica las tareas de mantenimiento. Asimismo, la estructura propuesta permite que el sistema pueda evolucionar en el futuro mediante la incorporación de nuevos módulos, como mecanismos adicionales de seguridad o integración con estándares de interoperabilidad en el ámbito de la salud.

3.2.2 Casos de uso

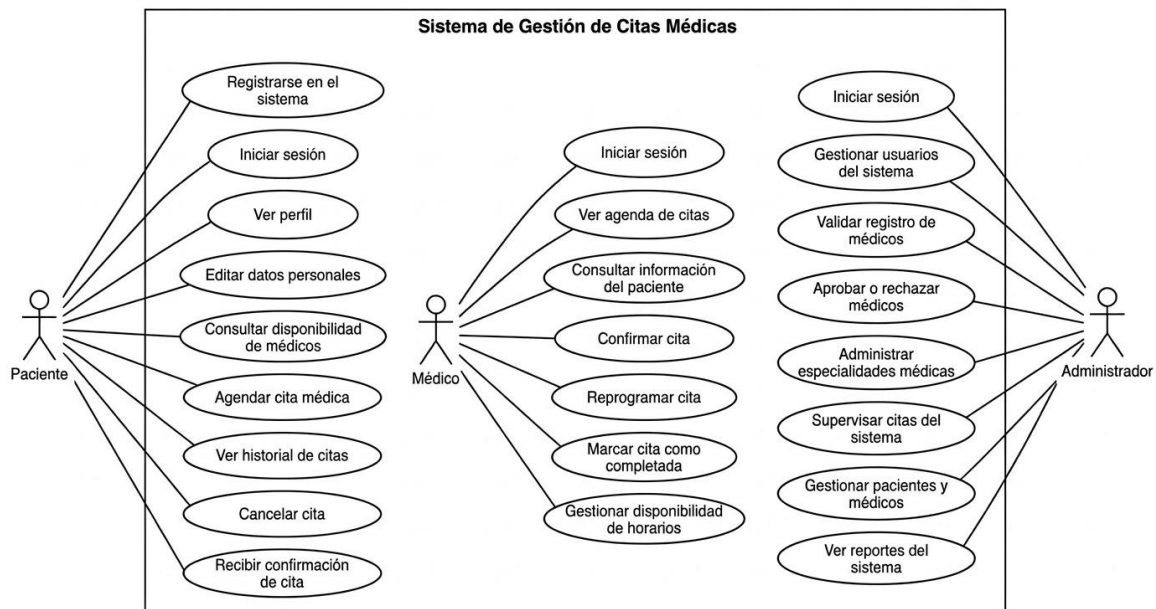


Figura 2 Diagrama general de Casos de uso

En la figura 2 se presenta el diagrama general de casos de uso del sistema web para la gestión segura del historial médico electrónico. El diagrama muestra la interacción entre los actores principales y las funcionalidades que permiten registrar usuarios, autenticar sesiones, consultar información clínica, generar autorizaciones temporales y mantener trazabilidad de los accesos.

El sistema contempla tres actores principales: Paciente, Médico y Administrador. El paciente administra su perfil, consulta su historial, genera tokens y revisa auditoría; el médico consulta historiales únicamente cuando cuenta con autorización válida y registra nuevas consultas cuando el permiso lo permite; el administrador supervisa usuarios, valida médicos y mantiene el control general de las cuentas.

El paciente es el actor central de la propuesta, ya que conserva control sobre la información médica asociada a su cuenta. Entre sus principales casos de uso se encuentran registrarse, iniciar sesión, actualizar su perfil médico base, consultar su historial clínico, generar tokens de acceso, revisar sus tokens activos o expirados,

revocar autorizaciones y consultar los eventos de auditoría vinculados con su expediente.

El médico interactúa con el sistema como usuario clínico autorizado. Sus funciones se concentran en iniciar sesión, validar un token proporcionado por el paciente, consultar el historial médico permitido y registrar una consulta médica cuando el nivel de acceso otorgado lo autoriza. Además, para proteger la información sensible, el médico debe contar con una cuenta activa y validada antes de ejecutar operaciones clínicas dentro del sistema.

Finalmente, el administrador tiene un rol de supervisión dentro de la plataforma. Este actor puede consultar usuarios registrados, cambiar roles, activar o desactivar cuentas y aprobar o rechazar médicos pendientes. Estas funciones permiten mantener un control mínimo sobre la identidad de los profesionales de salud y reducen el riesgo de que usuarios no validados accedan a funciones clínicas.

En conjunto, los casos de uso permiten describir el comportamiento funcional esperado del sistema y sirven como puente entre los requerimientos, el diseño de la base de datos y la implementación de los módulos del prototipo. Las tablas siguientes presentan los casos de uso que se consideran centrales para la versión implementada y para las funciones que se proyectan completar dentro del mismo alcance.

Casos de uso detallados:

No. y nombre de CU:	CU-D01 – Control de acceso al historial médico
Fuentes:	Modelo de control de acceso centrado en el paciente, requerimientos de seguridad.
Actor(es):	Paciente, Médico
Descripción:	Este caso de uso describe el mecanismo mediante el cual el paciente autoriza de forma explícita el acceso a su historial médico electrónico, y el médico accede únicamente cuando dicha autorización es válida. El sistema actúa como intermediario validando permisos y registrando los accesos.
Pre-Condiciones:	El paciente y el médico deben estar registrados en el sistema. El paciente debe contar con historial médico registrado.
Flujo básico (escenario de éxito):	El paciente genera una autorización de acceso con parámetros definidos. El sistema crea un token asociado a dicha autorización. El médico solicita acceso utilizando el token. El sistema valida el token y los permisos asociados. El sistema permite el acceso al historial médico.
Flujo alternativo (escenarios de fracaso):	El token es inválido, expirado o revocado; el sistema deniega el acceso.
Post-Condiciones:	El acceso autorizado queda registrado para su trazabilidad.
Notas:	Este caso de uso representa el núcleo funcional del sistema.

No. y nombre de CU:	CU-D02 – Gestión del historial médico electrónico
Fuentes:	Análisis de la fragmentación del expediente clínico.
Actor(es):	Paciente
Descripción:	Este caso de uso modela la forma en que el paciente administra su historial médico electrónico, permitiendo el registro, consulta y actualización de información clínica dentro del sistema.
Pre-Condiciones:	Este caso de uso modela la forma en que el paciente administra su historial médico electrónico, permitiendo el registro, consulta y actualización de información clínica dentro del sistema.
Flujo básico (escenario de éxito):	El paciente accede al módulo de historial médico. El sistema muestra la información clínica registrada. El paciente registra o actualiza información médica. El sistema almacena los cambios de forma segura.
Flujo alternativo (escenarios de fracaso):	Error en el almacenamiento de datos; el sistema cancela la operación.
Post-Condiciones:	El historial médico queda actualizado.
Notas:	El acceso y modificación del historial está restringido al paciente.

No. y nombre de CU:	CU-D03 – Auditoría y trazabilidad de accesos
Fuentes:	Requerimientos de trazabilidad y seguridad de la información.
Actor(es):	Paciente
Descripción:	Este caso de uso permite registrar y consultar los eventos relacionados con el acceso al historial médico, garantizando la trazabilidad y el control por parte del paciente.
Pre-Condiciones:	El paciente debe estar autenticado.
Flujo básico (escenario de éxito):	El sistema registra automáticamente cada acceso al historial médico. El paciente accede al módulo de auditoría. El sistema muestra los registros de acceso.
Flujo alternativo (escenarios de fracaso):	No existen registros disponibles; el sistema muestra un mensaje informativo.
Post-Condiciones:	El paciente visualiza el historial de accesos.
Notas:	La auditoría es un elemento clave para el cumplimiento de principios de seguridad.

No. y nombre de CU:	CU-01 – Registro de Usuario
Fuentes:	Análisis de requerimientos funcionales, necesidad de autenticación segura y gestión de identidad.
Actor(es):	Paciente (principal) Profesional de la salud (secundario)
Descripción:	Permite a un usuario crear una cuenta en el sistema proporcionando información básica y credenciales de acceso.
Pre-Condiciones:	• El usuario no debe estar previamente registrado. • El sistema debe estar disponible.
Flujo básico (escenario de éxito):	• El actor selecciona la opción “Registrarse”. • El sistema muestra el formulario de registro. • El actor ingresa datos personales y credenciales. • El actor confirmó la información. • El sistema valida que no exista una cuenta previa con el mismo correo. • El sistema almacena la información en la base de datos. • El sistema confirma el registro exitoso.
Flujo alternativo (escenarios de fracaso):	A1. Correo ya registrado • El sistema detecta duplicidad. • Muestra mensaje de error. A2. Datos incompletos o inválidos • El sistema solicita corrección.
Post-Condiciones:	• Se crea un nuevo usuario en estado activo. • El usuario puede iniciar sesión.

Notas:	• El correo debe ser único. • La contraseña se almacena cifrada.
---------------	--

No. y nombre de CU:	CU-02 – Inicio de Sesión
Fuentes:	Requerimiento de autenticación y control de acceso.
Actor(es):	Paciente Profesional de la salud Administrador
Descripción:	Permite a un usuario autenticarse en el sistema mediante credenciales válidas.
Pre-Condiciones:	• El usuario debe estar registrado. • La cuenta debe estar activa.
Flujo básico (escenario de éxito):	• El actor selecciona “Iniciar sesión”. • Ingresa correo y contraseña. • El sistema valida credenciales. • El sistema genera sesión autenticada. • El sistema redirige al panel principal según rol.
Flujo alternativo (escenarios de fracaso):	A1. Credenciales incorrectas • El sistema muestra un mensaje de error. A2. Cuenta bloqueada • El sistema informa restricción de acceso.
Post-Condiciones:	• Sesión activa iniciada. • Se registra evento de inicio de sesión en auditoría.
Notas:	• Se registran intentos de acceso. • La sesión debe ser segura.

No. y nombre de CU:	CU-03 – Generar Token de Acceso
Fuentes:	Modelo de control de acceso centrado en el paciente.
Actor(es):	Paciente
Descripción:	Permite al paciente generar un token único para autorizar el acceso temporal a su historial médico.
Pre-Condiciones:	● Paciente autenticado. ● Paciente con historial médico registrado.
Flujo básico (escenario de éxito):	● El paciente selecciona “Generar token”. ● Define nivel de acceso (lectura o edición). ● Define vigencia temporal. ● Confirma generación. ● El sistema crea un token único. ● El sistema almacena token con estado activo. ● El sistema muestra token generado.
Flujo alternativo (escenarios de fracaso):	A1. Vigencia inválida ● El sistema solicita corrección. A2. Error en almacenamiento ● El sistema notifica error técnico.
Post-Condiciones:	● Token activo registrado en base de datos. ● Token disponible para ser compartido.
Notas:	● El token debe ser único y no predecible. ● Debe tener una vigencia definida.

No. y nombre de CU:	CU-04 – Validar Token y Consultar Historial Médico
Fuentes:	Requerimiento de acceso autorizado mediante token.
Actor(es):	Profesional de la salud
Descripción:	Permite al profesional ingresar un token válido para acceder al historial médico del paciente.
Pre-Condiciones:	● Profesional autenticado. ● Token proporcionado por el paciente.
Flujo básico (escenario de éxito):	● El profesional ingresa token. ● El sistema valida la existencia del token. ● El sistema verifica la vigencia. ● El sistema verifica estado (activo). ● El sistema concede acceso según nivel definido. ● El sistema registra acceso en auditoría.
Flujo alternativo (escenarios de fracaso):	A1. Token inexistente ● El sistema muestra errores. A2. Token expirado ● El sistema niega acceso. A3. Token revocado ● El sistema bloquea el acceso.
Post-Condiciones:	● Acceso concedido o denegado según validación. ● Registro en bitácora de intento de acceso.
Notas:	● Se valida el estado y vigencia del token. ● El acceso queda registrado en auditoría.

No. y nombre de CU:	CU-05 – Revocar Token de Acceso
Fuentes:	Modelo de control de acceso con revocabilidad.
Actor(es):	Paciente
Descripción:	Permite al paciente invalidar un token previamente generado antes de su fecha de expiración.
Pre-Condiciones:	● Paciente autenticado. ● Existencia de token activo.
Flujo básico (escenario de éxito):	● El paciente accede a lista de tokens activos. ● Selecciona token. ● Selecciona “Revocar”. ● El sistema cambia estado a revocado. ● El sistema confirma la revocación.
Flujo alternativo (escenarios de fracaso):	A1. Token ya expirado ● El sistema informa estado. A2. Error en actualización ● El sistema notifica error técnico.
Post-Condiciones:	● Token queda en estado revocado. ● No puede ser utilizado nuevamente. ● Se registra acción en auditoría.
Notas:	● La revocación es inmediata. ● El token no puede reactivarse.

No. y nombre de CU:	CU-06 – Consultar auditoría de accesos
Fuentes:	Requerimientos de trazabilidad, seguridad de la información y transparencia para el paciente.
Actor(es):	Paciente / Administrador
Descripción:	Permite consultar los registros de auditoría generados por el sistema, incluyendo acciones relacionadas con visualización de perfil, actualización de datos, generación de tokens, consulta de historial y registro de consultas médicas.
Pre-Condiciones:	El actor debe estar autenticado. / Deben existir eventos registrados o el sistema debe mostrar un estado informativo vacío.
Flujo básico (escenario de éxito):	El actor accede al módulo de auditoría. / El sistema consulta los registros asociados al usuario o al paciente. / El sistema muestra fecha, acción realizada, descripción e información técnica disponible. / El actor revisa los eventos para identificar accesos o modificaciones relevantes.
Flujo alternativo (escenarios de fracaso):	A1. No existen registros disponibles / El sistema muestra un mensaje informativo. / A2. Usuario sin permisos / El sistema bloquea la consulta y deniega el acceso.
Post-Condiciones:	El actor visualiza los eventos registrados sin modificar la información clínica.
Notas:	La auditoría no sustituye controles preventivos, pero fortalece la trazabilidad y permite detectar accesos inusuales.

No. y nombre de CU:	CU-07 – Registrar consulta médica
Fuentes:	Requerimientos funcionales del sistema, gestión de historial clínico.
Actor(es):	Médico validado
Descripción:	Permite al médico validado registrar una nueva consulta médica en el historial del paciente, incluyendo motivo de consulta, diagnóstico, tratamiento y observaciones.
Pre-Condiciones:	• El médico debe estar autenticado. • El médico debe tener acceso autorizado mediante token válido.
Flujo básico (escenario de éxito):	• El médico accede al historial médico del paciente. • Selecciona la opción “Registrar consulta”. • El sistema muestra el formulario de consulta médica. • El médico captura: • motivo de consulta • diagnóstico • tratamiento • observaciones • El médico confirma el registro. • El sistema valida los datos. • El sistema guarda la consulta en la base de datos. • El sistema muestra confirmación de registro exitoso. • El sistema registra la acción en auditoría.
Flujo alternativo (escenarios de fracaso):	A1 – Datos incompletos • El sistema detecta campos obligatorios vacíos. • Muestra error. A2 – Sin permisos de edición

No. y nombre de CU:	CU-07 – Registrar consulta médica
	• El token solo permite lectura. • El sistema bloquea la acción. A3 – Error de sistema • El sistema no guarda la información. • Muestra mensaje de error.
Post-Condiciones:	• La consulta médica queda registrada en el historial del paciente. • Se actualiza el historial clínico. • Se registra la acción en auditoría.
Notas:	En la implementación actual el backend valida que el médico exista y esté aprobado por el administrador. La restricción por nivel de token debe mantenerse como regla funcional del flujo de autorización.

Casos de uso complementarios propuestos para completar el alcance funcional:

No. y nombre de CU:	CU-08 – Actualizar perfil médico base del paciente
Fuentes:	Requerimientos de gestión de perfil, disponibilidad de información básica y control del paciente sobre sus datos.
Actor(es):	Paciente
Descripción:	Permite al paciente consultar y actualizar datos personales y clínicos básicos, como CURP, fecha de nacimiento, sexo, teléfono, dirección, grupo sanguíneo y alergias, según los campos definidos para el perfil.
Pre-Condiciones:	Paciente autenticado. / El perfil de paciente debe existir en el sistema.
Flujo básico (escenario de éxito):	El paciente accede a Mi Perfil Médico Base. / El sistema carga los datos existentes. / El paciente

	modifica los campos permitidos. / El sistema valida el formato de los datos. / El sistema guarda los cambios. / El sistema registra la acción en auditoría.
Flujo alternativo (escenarios de fracaso):	A1. Datos inválidos / El sistema solicita corrección. / A2. Perfil no encontrado / El sistema informa que no existe perfil asociado. / A3. Error de almacenamiento / El sistema notifica la falla.
Post-Condiciones:	El perfil del paciente queda actualizado y se registra el evento correspondiente.
Notas:	El nombre de usuario puede mantenerse restringido para evitar inconsistencias de identidad; los datos clínicos básicos pueden ampliarse conforme avance el prototipo.

No. y nombre de CU:	CU-09 – Administrar usuarios y validar médicos
Fuentes:	Requerimientos de control administrativo, gestión de identidad y seguridad de acceso a funciones clínicas.
Actor(es):	Administrador
Descripción:	Permite al administrador consultar usuarios registrados, filtrar por rol, cambiar roles, activar o desactivar cuentas y aprobar o rechazar solicitudes de médicos antes de permitirles ejecutar operaciones clínicas.
Pre-Condiciones:	Administrador autenticado. / El usuario objetivo debe existir en el sistema.
Flujo básico (escenario de éxito):	El administrador accede al módulo de usuarios. / El sistema muestra la lista de cuentas registradas. / El administrador selecciona un usuario. / El administrador ejecuta una acción de aprobación, rechazo, cambio de rol o cambio de estado. / El sistema actualiza la cuenta y confirma la operación.
Flujo alternativo (escenarios de fracaso):	A1. Usuario inexistente / El sistema informa que no se encontró el registro. / A2. Acción no permitida / El

sistema bloquea la operación. / A3. Error de actualización / El sistema notifica la falla.

Post-Condiciones:

El estado o rol del usuario queda actualizado conforme a la acción administrativa realizada.

Notas:

La validación del médico es importante porque evita que una cuenta recién registrada acceda inmediatamente a operaciones de consulta o registro de información clínica.

3.2.3 Diagramas de secuencia

3.2.4 Diagrama entidad-relación

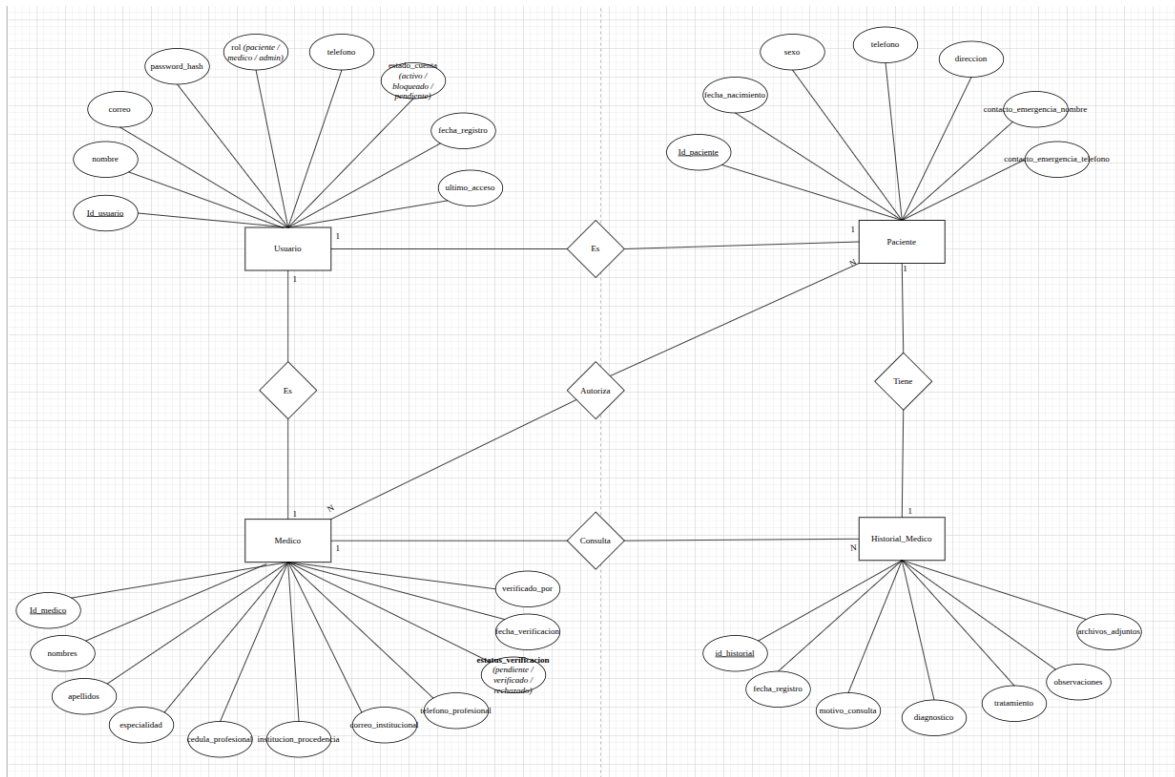


Figura 3 Modelo Entidad-Relación Conceptual

En la figura 3 se presenta el diagrama que corresponde al modelo entidad-relación lógico del sistema web propuesto para la gestión segura del historial médico

electrónico centrado en el paciente. En él se representan las principales entidades del sistema, como Usuario, Paciente, Médico, Historial Médico, Token y Registro de Auditoría, así como las relaciones necesarias para asociar cada registro clínico con el paciente correspondiente y, cuando aplique, con el médico que lo generó.

El modelo separa la autenticación general del usuario de los perfiles clínicos específicos. La entidad Usuario concentra credenciales, rol y estado de la cuenta; Paciente y Médico almacenan información particular de cada tipo de usuario; Historial Médico representa las consultas registradas; Token modela las autorizaciones temporales emitidas por el paciente; y Registro de Auditoría conserva evidencia de acciones relevantes realizadas dentro de la plataforma.

Este modelo lógico sienta las bases para la implementación técnica del sistema en una base de datos relacional, favoreciendo integridad referencial, separación de responsabilidades y control sobre las operaciones que afectan información médica sensible.

3.2.5 Algoritmos

3.2.6 Interfaces

En esta sección se describen las interfaces implementadas en el prototipo actual del sistema web para la gestión del historial médico electrónico centrado en el paciente. Actualmente, el sistema contempla las pantallas base de autenticación (registro e inicio de sesión), las cuales constituyen el punto de entrada a la plataforma.

Las interfaces fueron diseñadas considerando principios de claridad visual, validación de datos y estructura organizada de la información, garantizando una experiencia de usuario comprensible y coherente.



Figura 4. Interfaz de autenticación del sistema

La figura muestra la interfaz principal de autenticación del sistema, donde el usuario puede ingresar su dirección de correo electrónico y contraseña para registrarse o acceder a la plataforma. Se observa un diseño estructurado con etiquetas claras y un botón principal de acción (“Registrarse”), el cual orienta al usuario en el proceso. La disposición visual facilita la identificación de los elementos interactivos y mejora la experiencia de uso.

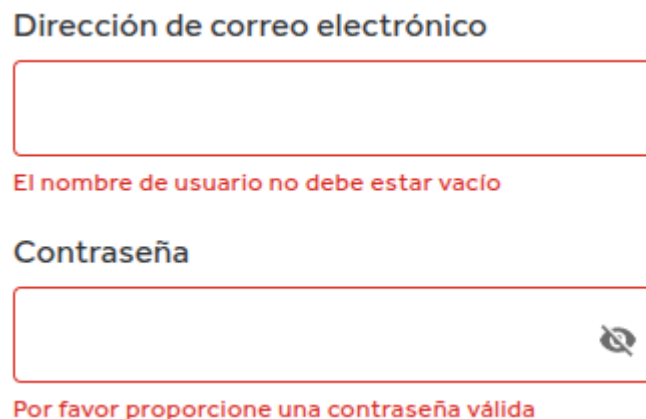


Figura 5. Validación e identificación de errores en formulario

En la figura 3 se presenta el comportamiento del sistema ante la introducción de datos incorrectos o incompletos en los campos del formulario. Los mensajes de error se muestran de manera visible en color rojo, indicando claramente la causa del problema (por ejemplo, campos obligatorios vacíos o contraseña inválida). Esta

retroalimentación inmediata permite al usuario corregir los datos de forma precisa, reduciendo errores y mejorando la interacción con el sistema.

Iniciar Sesión
Ingresa tus credenciales para continuar

Correo electrónico

Contraseña

Iniciar Sesión

¿No tienes cuenta? [Regístrate aquí](#)

Cuentas de prueba:

Figura 6. Organización estructurada del formulario de acceso

La figura 6 muestra el formulario de autenticación con los campos correctamente organizados mediante etiquetas asociadas a cada entrada. La relación entre los campos “Dirección de correo electrónico” y “Contraseña” se presenta de forma clara, junto con el botón de acción principal. La estructura ordenada facilita la comprensión del flujo de interacción y contribuye a una experiencia intuitiva y accesible.

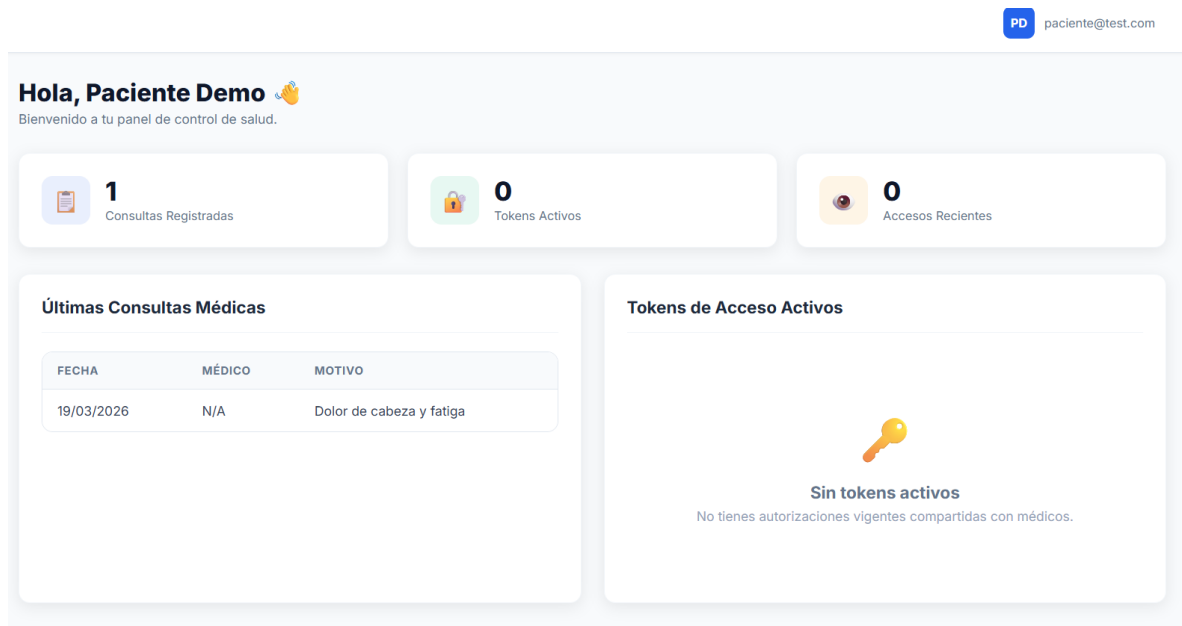


Figura 7. Organización estructurada del formulario de acceso

La figura 7 muestra el diseño del dashboard del paciente con sus respectivos registros.

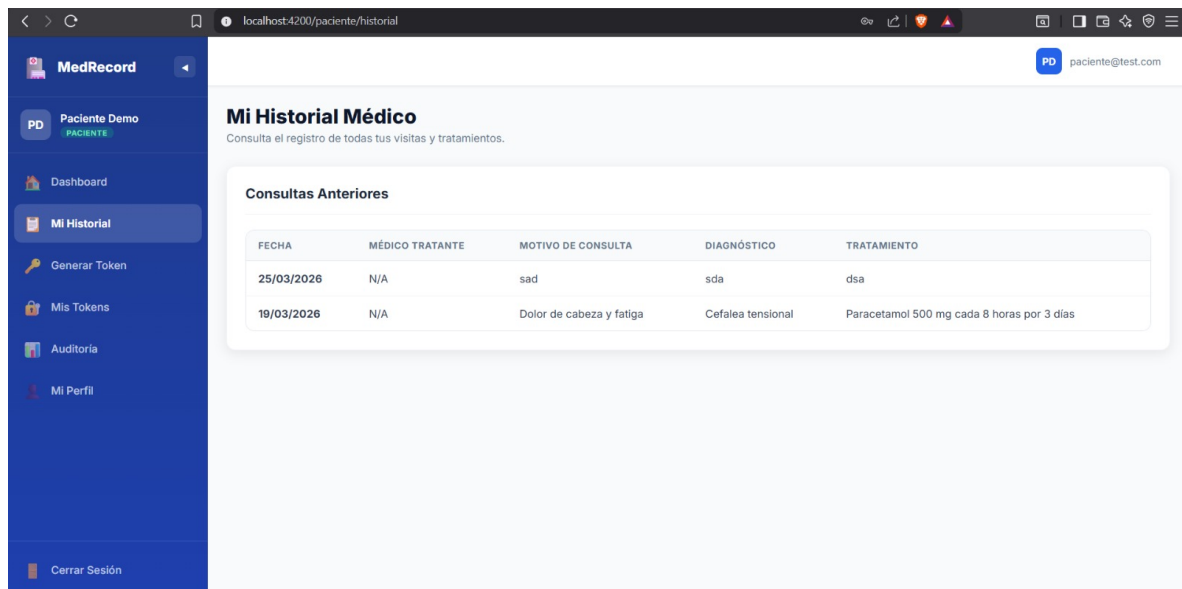


Figura 8. Historial Médico de Paciente

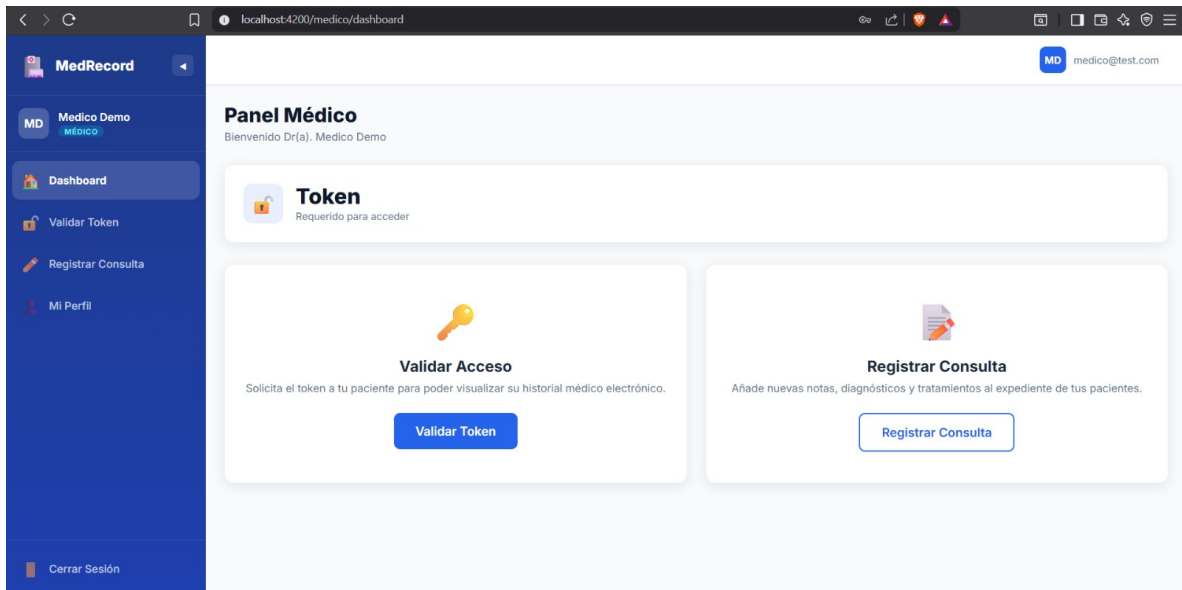


Figura 9.

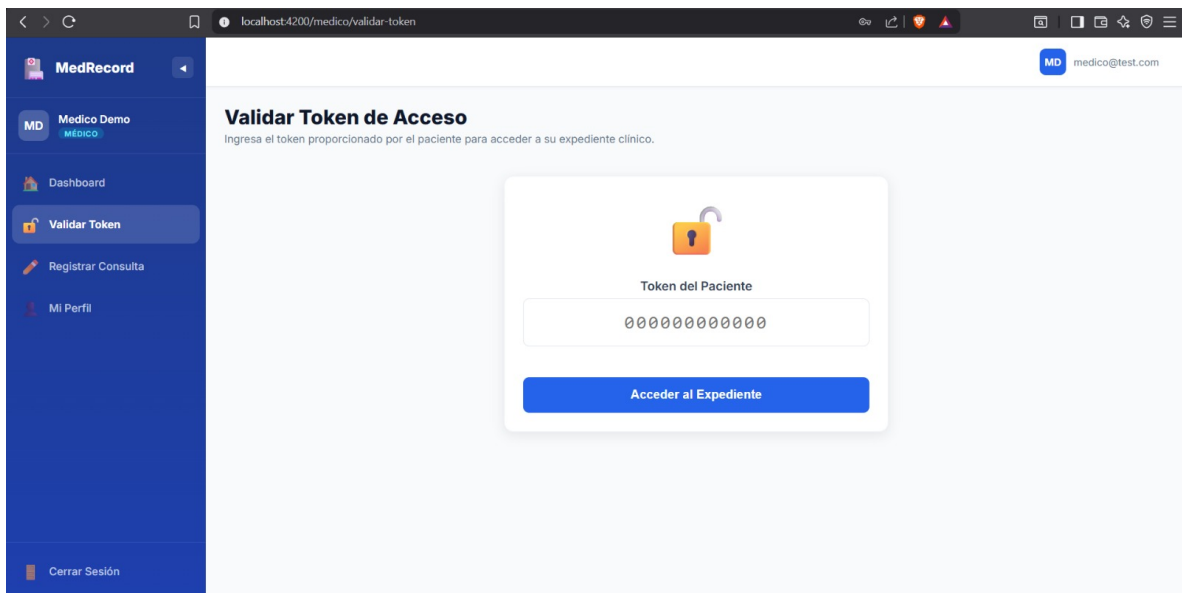


Figura 10. Organización estructurada del formulario de acceso

The screenshot displays the 'MedRecord' web application interface. On the left is a dark blue sidebar with the 'MedRecord' logo and a user profile 'MD Medico Demo'. Navigation links include 'Dashboard', 'Validar Token', 'Registrar Consulta' (highlighted), and 'Mi Perfil', along with a 'Cerrar Sesión' (Logout) button at the bottom. The main content area is titled 'Registrar Nueva Consulta' and includes a sub-header 'Añade una nueva entrada clínica al expediente del paciente.' A note states: 'Nota: Para registrar una consulta, necesitas asegurar tener el ID del paciente disponible, o que tengas acceso mediante token previamente validado. En una clínica real, el sistema selecciona al paciente automáticamente al escanear/validar token.' The form contains several input fields: a dropdown for 'Paciente' (selected: 'Paciente Demo (TEST000515HSLXXX01)'), a date picker for 'Fecha de la Consulta' (selected: '03/26/2026'), a text field for 'Motivo Principal' (placeholder: 'Ej: Dolor abdominal recurrente'), a text area for 'Diagnóstico Clínico' (placeholder: 'Descripción detallada del diagnóstico...'), and another text area for 'Tratamiento e Indicaciones' (placeholder: 'Medidas y pasos de tratamiento...').

Figura 11. Organización estructurada del formulario de acceso

Consideraciones

El prototipo implementado ya contempla módulos base para autenticación, perfil del paciente, historial médico, generación de tokens y auditoría. Las interfaces muestran una organización orientada a que el paciente pueda identificar rápidamente sus consultas registradas, tokens activos y eventos recientes de acceso. Como trabajo complementario dentro del mismo alcance, se propone completar la revocación de tokens desde el backend, reforzar la validación del nivel de acceso antes de permitir edición de registros y ampliar las vistas del médico y del administrador para cubrir todos los casos de uso definidos.

3.3 Implementación

3.4 Descripción del sistema

El prototipo implementado corresponde a una aplicación web compuesta por un frontend desarrollado en Angular y un backend desarrollado con NestJS. La comunicación entre ambas capas se realiza mediante servicios HTTP que exponen operaciones para autenticación, pacientes, médicos, historiales médicos, tokens y auditoría. Esta estructura permite que la interfaz de usuario se mantenga separada de la lógica de negocio y que las reglas de seguridad se concentren principalmente en el servidor.

En el módulo de autenticación, el sistema permite registrar usuarios e iniciar sesión mediante correo electrónico y contraseña. Las contraseñas se almacenan cifradas y, al autenticarse correctamente, el usuario recibe un token JWT que se utiliza para identificar la sesión en solicitudes posteriores. Además, el sistema maneja roles de usuario, principalmente paciente, médico y administrador, lo cual permite restringir funcionalidades según el perfil correspondiente.

El módulo de pacientes permite consultar y actualizar el perfil asociado al usuario autenticado. Este perfil concentra datos personales y clínicos básicos que pueden apoyar la identificación del paciente dentro del sistema. El módulo de historial médico permite que el paciente consulte sus registros clínicos y que el médico validado pueda registrar nuevas consultas asociadas a un paciente. Cada registro médico almacena datos como fecha de consulta, motivo, diagnóstico, tratamiento y observaciones.

El módulo de tokens permite que el paciente genere códigos alfanuméricos únicos con vigencia temporal, nivel de acceso y descripción opcional. Estos tokens funcionan como mecanismo de autorización explícita para que un profesional de la salud pueda acceder al historial del paciente. En la implementación actual, el token se valida en el backend revisando existencia y fecha de expiración; como mejora funcional, debe completarse la revocación desde el servidor y reforzarse la validación del nivel de acceso antes de permitir operaciones de edición.

El módulo de auditoría registra eventos relevantes del sistema, como consulta de perfil, actualización de datos y creación de registros médicos. Esta bitácora permite al paciente revisar actividad relacionada con su expediente y proporciona una base

para supervisar accesos. Aunque el prototipo se mantiene en un alcance académico, la inclusión de auditoría resulta fundamental porque conecta los requerimientos de seguridad con evidencia verificable dentro del sistema.

4 Experimentación, resultados y análisis

4.1 Técnica de muestreo

4.2 Participantes

4.3 Muestra

4.4 Metodología (procedimiento)

4.5 Resultados

4.6 Discusión

5 Conclusiones

Bibliografía

- Adler-Milstein, J., & Jha, A. K. (2017). HITECH Act drove large gains in hospital electronic health record adoption. *Health Affairs*, 36(8), 1416-1422. <https://doi.org/10.1377/hlthaff.2016.1651>
- Bass, L., Clements, P., & Kazman, R. (2021). *Software architecture in practice* (4th ed.). Addison-Wesley.
- Bates, D. W., Leape, L. L., Cullen, D. J., Laird, N., Petersen, L. A., Teich, J. M., Burdick, E., Hickey, M., Kleefield, S., Shea, B., Vander Vliet, M., & Seger, D. L. (1998). Effect of computerized physician order entry and a team intervention on prevention of serious medication errors. *JAMA*, 280(15), 1311-1316. <https://doi.org/10.1001/jama.280.15.1311>
- Baudendistel, I., Winkler, E. C., Kamradt, M., Brophy, S., Längst, G., Eckrich, F., Heinze, O., Bergh, B., Szecsenyi, J., & Ose, D. (2015). The patients' active role in managing a personal electronic health record: A qualitative analysis. *Supportive Care in Cancer*, 23(9), 2613-2621. <https://doi.org/10.1007/s00520-015-2620-1>
- Benson, T., & Grieve, G. (2016). *Principles of health interoperability: SNOMED CT, HL7 and FHIR* (3rd ed.). Springer.
- Blumenthal, D., & Tavenner, M. (2010). The meaningful use regulation for electronic health records. *New England Journal of Medicine*, 363(6), 501-504. <https://doi.org/10.1056/NEJMp1006114>
- Boonstra, A., & Broekhuis, M. (2010). Barriers to the acceptance of electronic medical records by physicians: From systematic review to taxonomy and interventions. *BMC Health Services Research*, 10, Article 231. <https://doi.org/10.1186/1472-6963-10-231>
- Chacon, S., & Straub, B. (2014). *Pro Git* (2nd ed.). Apress.
- Cichosz, S. L., Stausholm, M. N., Kronborg, T., Vestergaard, P., & Hejlesen, O. (2019). How to use blockchain for diabetes health care data and access management: An operational concept. *Journal of Diabetes Science and Technology*, 13(2), 248-253. <https://doi.org/10.1177/1932296818790281>
- Cimino, J. J. (2013). Improving the electronic health record: Are clinicians getting what they wished for? *JAMA*, 309(10), 991-992. <https://doi.org/10.1001/jama.2013.890>
- Diario Oficial de la Federación. (2010, 5 de julio). Ley Federal de Protección de Datos Personales en Posesión de los Particulares. <https://www.diputados.gob.mx/LeyesBiblio/pdf/LFPDPPP.pdf>
- Elmasri, R., & Navathe, S. B. (2016). *Fundamentals of database systems* (7th ed.). Pearson.
- Ferraiolo, D. F., Sandhu, R., Gavrila, S., Kuhn, D. R., & Chandramouli, R. (2001). Proposed NIST standard for role-based access control. *ACM Transactions on Information and System Security*, 4(3), 224-274. <https://doi.org/10.1145/501978.501980>
- Fielding, R. T. (2000). *Architectural styles and the design of network-based software architectures* [Doctoral dissertation, University of California, Irvine]. <https://www.ics.uci.edu/~fielding/pubs/dissertation/top.htm>
- Fowler, M. (2002). *Patterns of enterprise application architecture*. Addison-Wesley.
- Gamma, E., Helm, R., Johnson, R., & Vlissides, J. (1994). *Design patterns: Elements of reusable object-oriented software*. Addison-Wesley.
- Giardina, T. D., Menon, S., Parrish, D. E., Sittig, D. F., & Singh, H. (2014). Patient access to medical records and healthcare outcomes: A systematic review. *Journal of the American Medical Informatics Association*, 21(4), 737-741. <https://doi.org/10.1136/amiajnl-2013-002239>
- GitHub. (2024). *GitHub Docs: About version control and Git*. <https://docs.github.com/>

- Goldzweig, C. L., Towfigh, A., Maglione, M., & Shekelle, P. G. (2009). Costs and benefits of health information technology: New trends from the literature. *Health Affairs*, 28(2), w282-w293. <https://doi.org/10.1377/hlthaff.28.2.w282>
- Hardt, D. (2012). The OAuth 2.0 authorization framework (RFC 6749). Internet Engineering Task Force. <https://doi.org/10.17487/RFC6749>
- HL7 International. (2019). FHIR Release 4: Fast Healthcare Interoperability Resources. <https://hl7.org/fhir/R4/>
- IEEE Computer Society. (2014). Guide to the Software Engineering Body of Knowledge (SWEBOK Guide), Version 3.0. IEEE Computer Society.
- ISO/IEC. (2022a). ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection: Information security management systems: Requirements. International Organization for Standardization.
- ISO/IEC. (2022b). ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection: Information security controls. International Organization for Standardization.
- Jha, A. K., DesRoches, C. M., Campbell, E. G., Donelan, K., Rao, S. R., Ferris, T. G., Shields, A., Rosenbaum, S., & Blumenthal, D. (2009). Use of electronic health records in U.S. hospitals. *New England Journal of Medicine*, 360(16), 1628-1638. <https://doi.org/10.1056/NEJMsa0900592>
- Jones, M., Bradley, J., & Sakimura, N. (2015). JSON Web Token (JWT) (RFC 7519). Internet Engineering Task Force. <https://doi.org/10.17487/RFC7519>
- Kaushal, R., & Bates, D. W. (2003). Effects of computerized physician order entry and clinical decision support systems on medication safety: A systematic review. *Archives of Internal Medicine*, 163(12), 1409-1416. <https://doi.org/10.1001/archinte.163.12.1409>
- Kripalani, S., LeFevre, F., Phillips, C. O., Williams, M. V., Basaviah, P., & Baker, D. W. (2007). Deficits in communication and information transfer between hospital-based and primary care physicians: Implications for patient safety and continuity of care. *JAMA*, 297(8), 831-841. <https://doi.org/10.1001/jama.297.8.831>
- Kruse, C. S., Stein, A., Thomas, H., & Kaur, H. (2018). The use of electronic health records to support population health: A systematic review of the literature. *Journal of Medical Systems*, 42, Article 214. <https://doi.org/10.1007/s10916-018-1075-6>
- Menachemi, N., & Collum, T. H. (2011). Benefits and drawbacks of electronic health record systems. *Risk Management and Healthcare Policy*, 4, 47-55. <https://doi.org/10.2147/RMHP.S12985>
- Mozilla Developer Network. (2024). Web technology for developers. <https://developer.mozilla.org/>
- National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (SP 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. <https://doi.org/10.6028/NIST.CSWP.29>
- Nielsen, J. (1994). Usability engineering. Morgan Kaufmann.
- Norman, D. A. (2013). The design of everyday things (Revised and expanded ed.). Basic Books.
- Object Management Group. (2017). OMG Unified Modeling Language (OMG UML), Version 2.5.1. <https://www.omg.org/spec/UML/2.5.1/>
- Open Source Initiative. (2007). The open source definition. <https://opensource.org/osd/>
- OWASP Foundation. (2021). OWASP Top 10: The ten most critical web application security risks. <https://owasp.org/Top10/>

- Pagliari, C., Detmer, D., & Singleton, P. (2007). Potential of electronic personal health records. *BMJ*, 335(7615), 330-333. <https://doi.org/10.1136/bmj.39279.482963.AD>
- Paydar, S., Emami, H., Asadi, F., Moghaddasi, H., & Hosseini, A. (2021). Functions and outcomes of personal health records for patients with chronic diseases: A systematic review. *Perspectives in Health Information Management*, 18(Spring), 11.
- Poss-Doering, R., Kunz, A., Pohlmann, S., Hofmann, H., Kiel, M., Winkler, E. C., Ose, D., & Szecsenyi, J. (2018). Utilizing a prototype patient-controlled electronic health record in Germany: Qualitative analysis of user-reported perceptions and perspectives. *JMIR Formative Research*, 2(2), e10411. <https://doi.org/10.2196/10411>
- PostgreSQL Global Development Group. (2024). PostgreSQL documentation. <https://www.postgresql.org/docs/>
- Pressman, R. S., & Maxim, B. R. (2020). *Software engineering: A practitioner's approach* (9th ed.). McGraw-Hill Education.
- Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE*, 63(9), 1278-1308. <https://doi.org/10.1109/PROC.1975.9939>
- Schwaber, K., & Sutherland, J. (2020). *The Scrum Guide: The definitive guide to Scrum*. <https://scrumguides.org/scrum-guide.html>
- Secretaría de Salud. (2012a). Norma Oficial Mexicana NOM-024-SSA3-2012, Sistemas de información de registro electrónico para la salud. *Diario Oficial de la Federación*.
- Secretaría de Salud. (2012b). Norma Oficial Mexicana NOM-004-SSA3-2012, Del expediente clínico. *Diario Oficial de la Federación*.
- Silberschatz, A., Korth, H. F., & Sudarshan, S. (2020). *Database system concepts* (7th ed.). McGraw-Hill Education.
- Sittig, D. F., & Singh, H. (2012). Rights and responsibilities of users of electronic health records. *CMAJ*, 184(13), 1479-1483. <https://doi.org/10.1503/cmaj.111599>
- Sommerville, I. (2016). *Software engineering* (10th ed.). Pearson.
- Tang, P. C., Ash, J. S., Bates, D. W., Overhage, J. M., & Sands, D. Z. (2006). Personal health records: Definitions, benefits, and strategies for overcoming barriers to adoption. *Journal of the American Medical Informatics Association*, 13(2), 121-126. <https://doi.org/10.1197/jamia.M2025>
- Vest, J. R., & Gamm, L. D. (2010). Health information exchange: Persistent challenges and new strategies. *Journal of the American Medical Informatics Association*, 17(3), 288-294. <https://doi.org/10.1136/jamia.2010.003673>
- World Health Organization. (2021). *Global strategy on digital health 2020-2025*. World Health Organization. <https://www.who.int/publications/i/item/9789240020924>
- Zhan, W., Chen, C. L., Weng, W., Tsaur, W. J., Lim, Z. Y., & Deng, Y. Y. (2022). Incentive EMR sharing system based on consortium blockchain and IPFS. *Healthcare*, 10(10), 1840. <https://doi.org/10.3390/healthcare10101840>

Anexos

Casos de uso

Diagramas de secuencia

Código

Encuestas

Manual de usuario

Publicaciones